

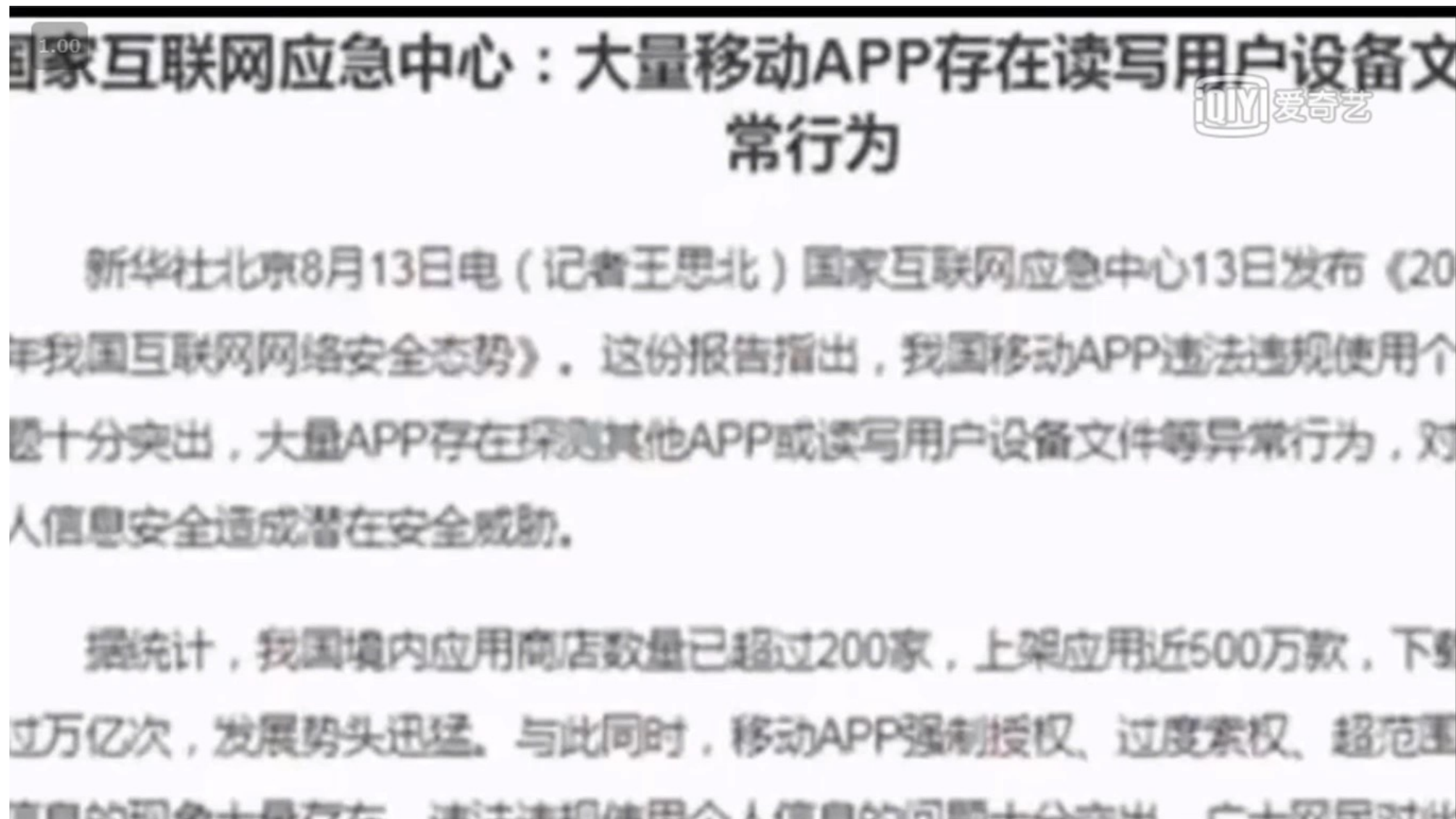


《计算机科学导论》课程

信息安全

上海交通大学计算机科学导论课程组







目 录

01

基础知识概述

02

密码学

03

软件系统与安全

04

网络信息安全

01.基本知识概述：信息安全定义

什么是信息？



信息是用来消除不确定性的东西。

克劳德·香农 (1916-2001)
Claude Elwood Shannon
数学家，信息论创始人



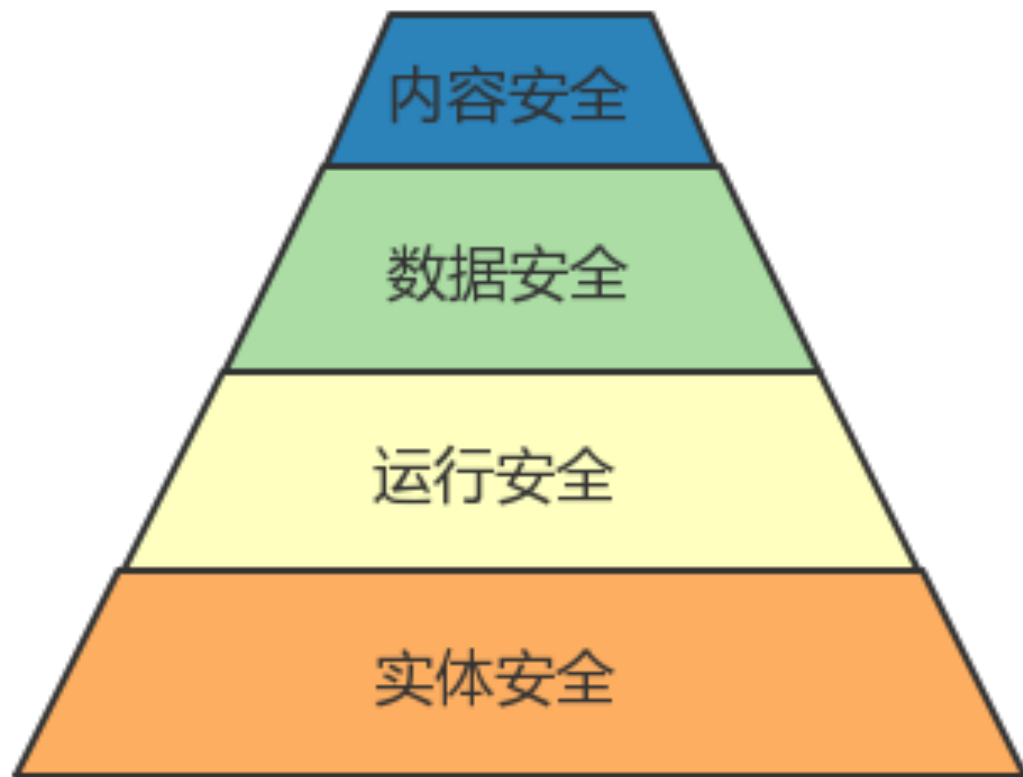
信息是事物运动的状态及其变化方式。

钟义信 (1940-)
济南大学人工智能研究院院长

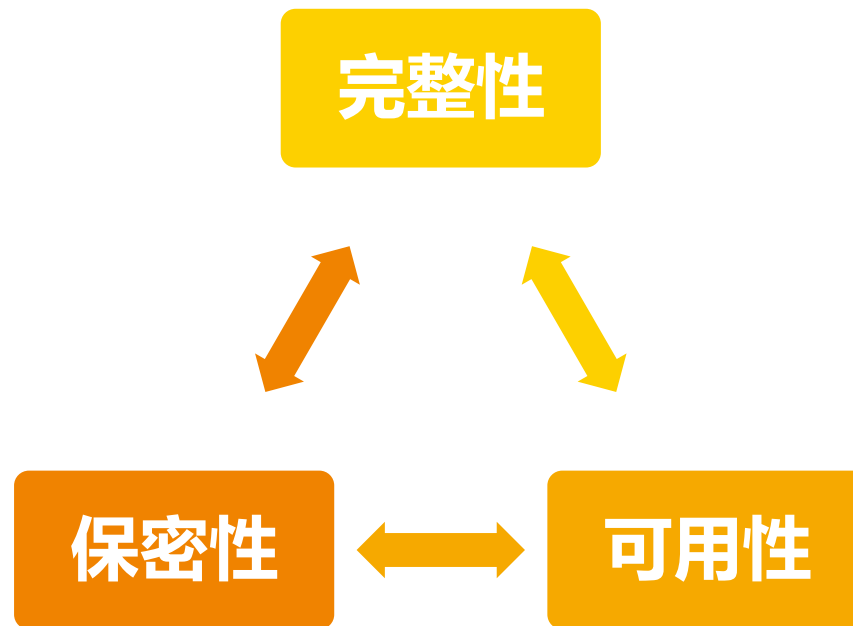
什么是信息安全？

- ISO：在技术上和管理上为数据处理系统建立的安全保护，保护计算机硬件、软件和数据不因偶然和恶意的原因而遭到破坏、更改和泄露。
*ISO: International Organization for Standardization, 国际标准化组织, 此处转指信息安全管理要求
- 维基百科：意为保护信息及信息系统免受未经授权的进入、使用、披露、破坏、修改、检视、记录及销毁。

01.基本知识概述：信息安全理解的两种观点



信息安全分层结构
面向应用的信息安全框架
(工程角度)



信息安全金三角结构
面向属性的信息安全框架

01.基本知识概述：安全的三要素



保密性

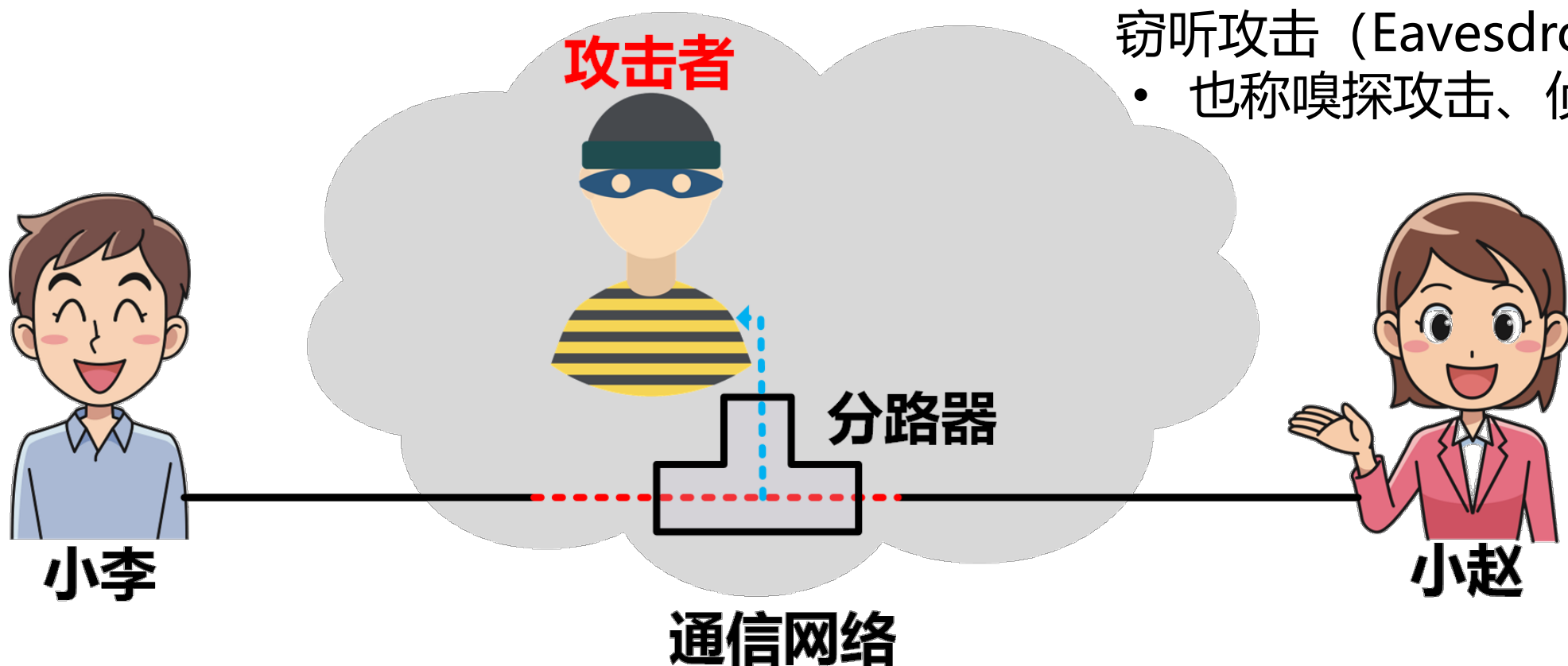
不该知道的人，不让他知道！

保密性属性：确保信息没有非授权的泄漏，不被非授权的个人、组织和计算机程序使用

01.基本知识概述：安全的三要素

保密性/机密性 (Confidentiality)

- 信息不能泄露给**未获授权的用户、实体或过程**



窃听攻击 (Eavesdropping)
• 也称嗅探攻击、侦听攻击

01.基本知识概述：安全的三要素



完整性

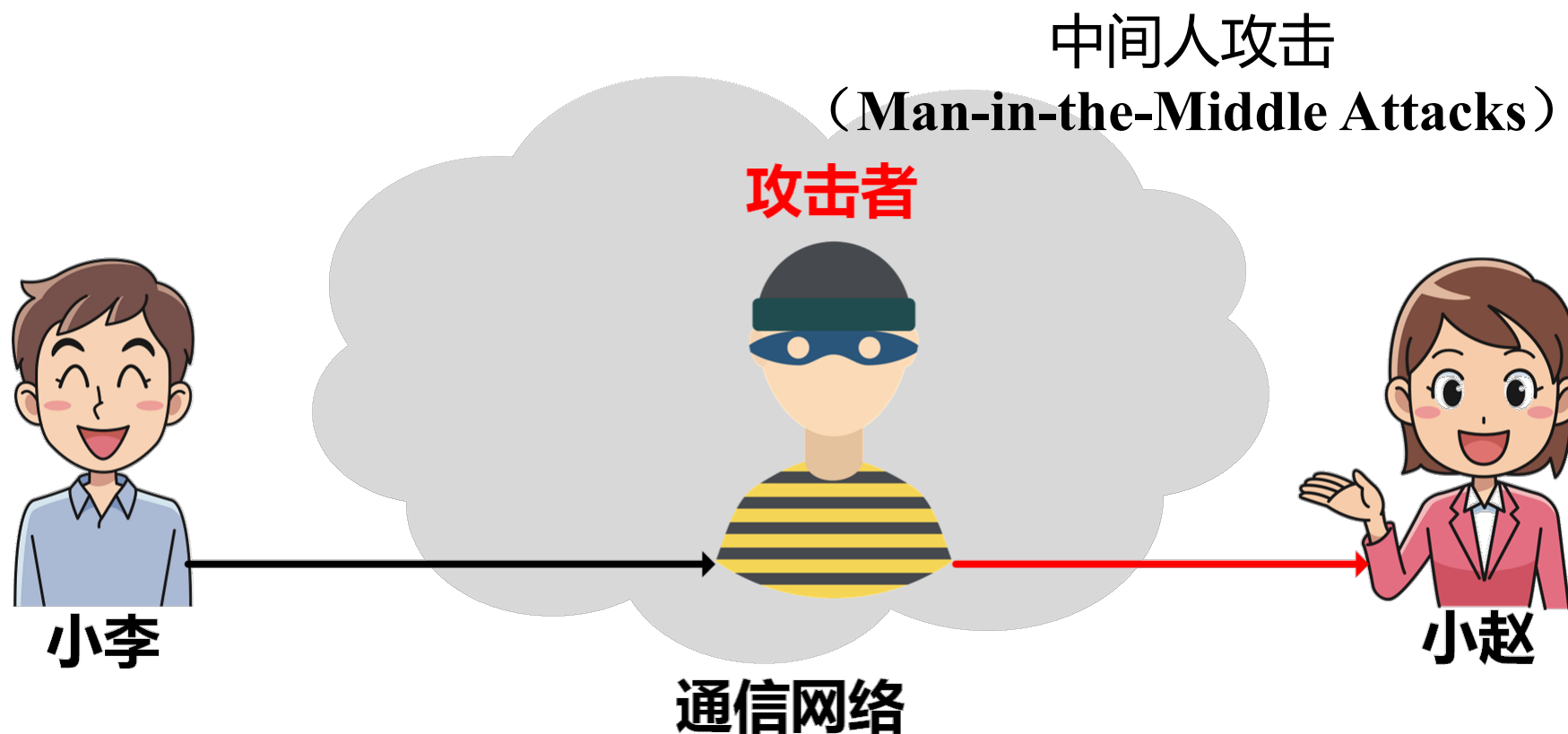
信息不能追求残缺美！

完整性属性：确保信息没有遭到篡改和破坏

01.基本知识概述：安全的三要素

完整性 (Integrity)

- 在信息使用全过程中保证**信息及其属性**真实、完整
- 数据完整，身份真实、正确



01.基本知识概述：安全三要素



可用性

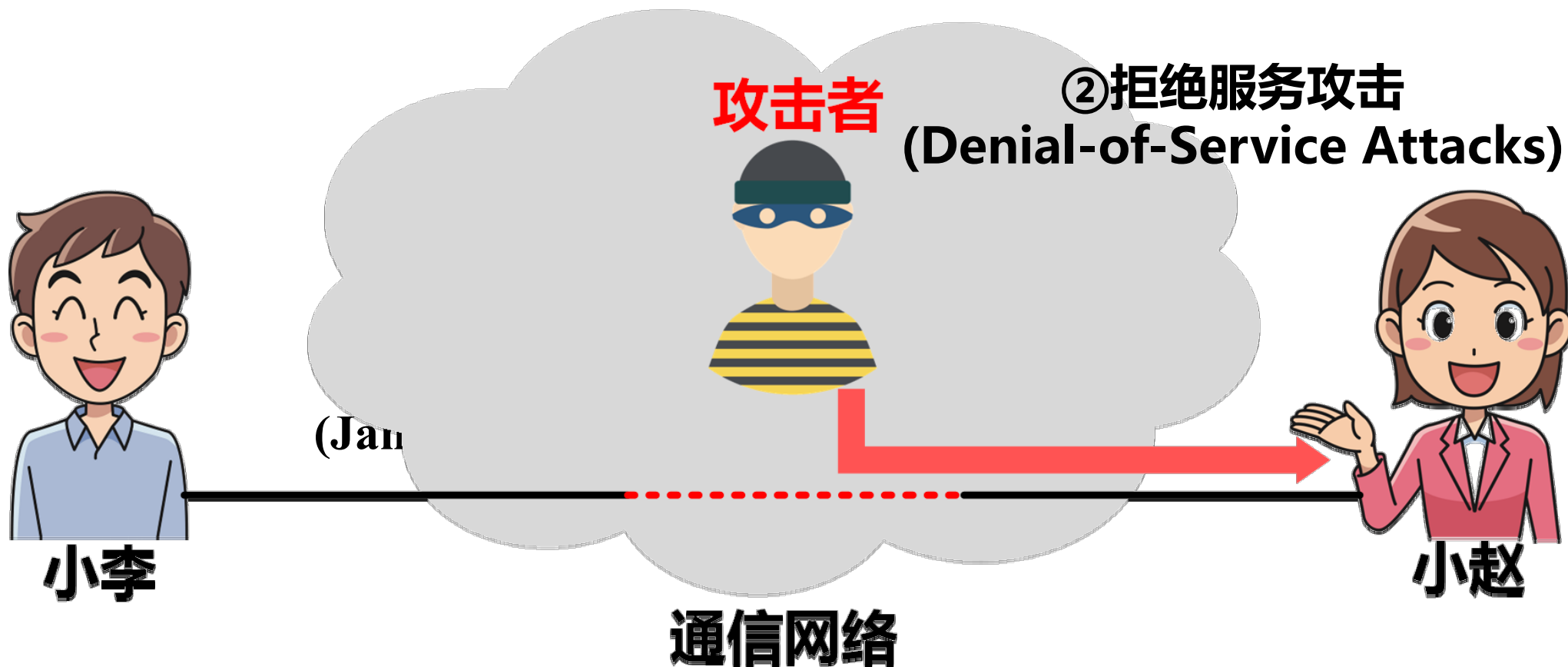
信息要方便、快捷！

可用性属性：确保拥有授权的用户或程序可以及时、正常使用信息

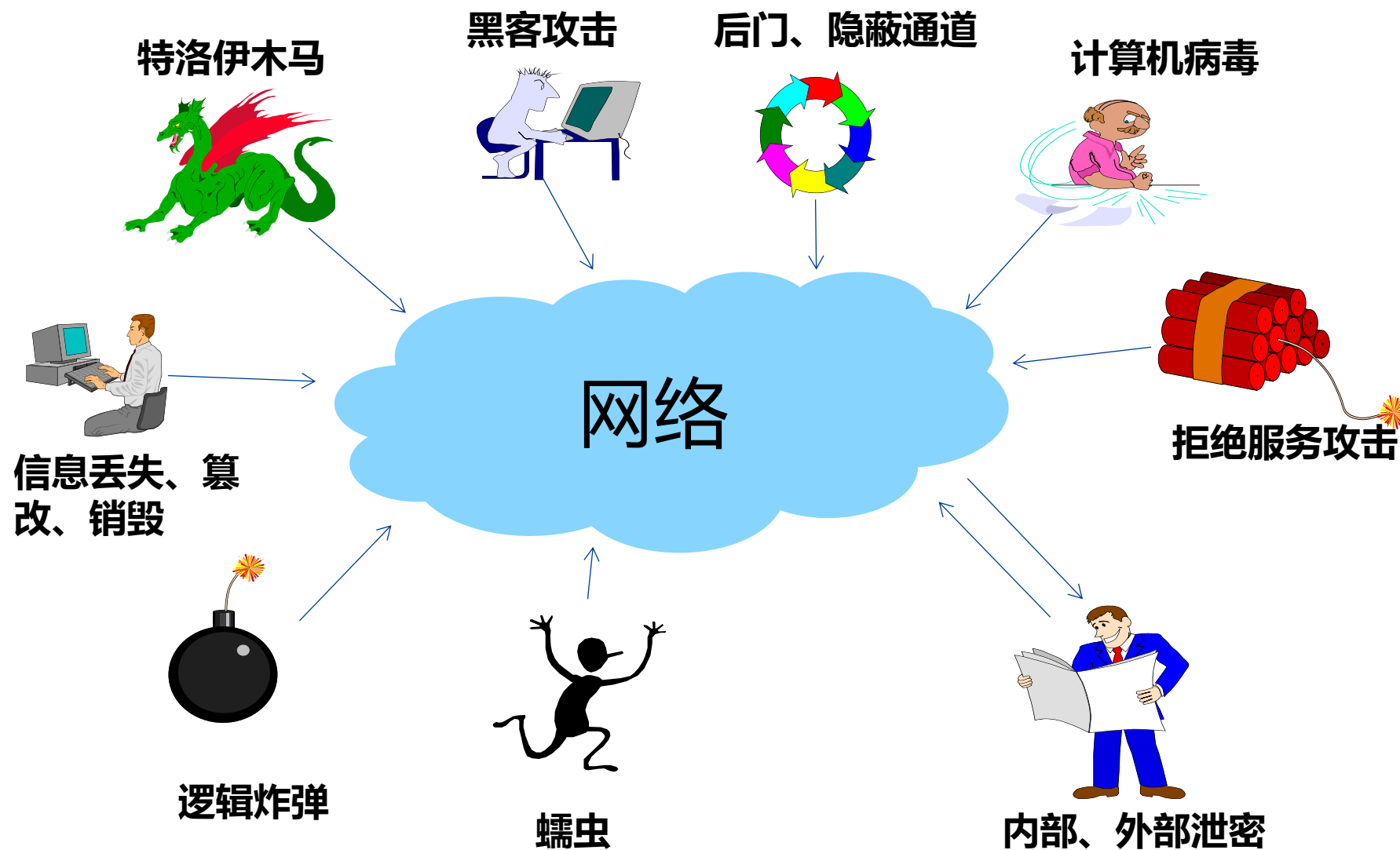
01.基本知识概述：安全的三要素

可用性 (Availability)

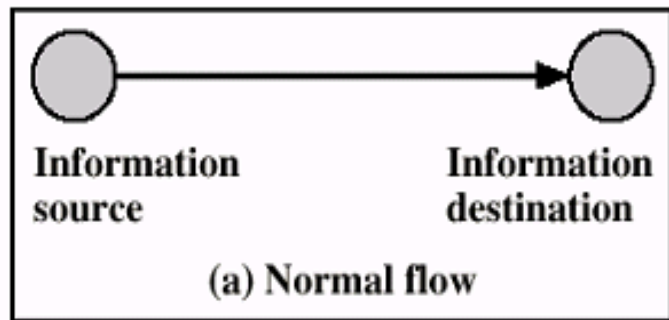
- 授权用户能对数据进行**及时、可靠的访问**



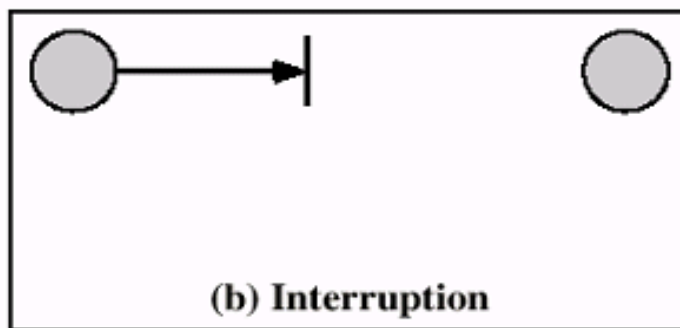
01.基本知识概述：安全威胁



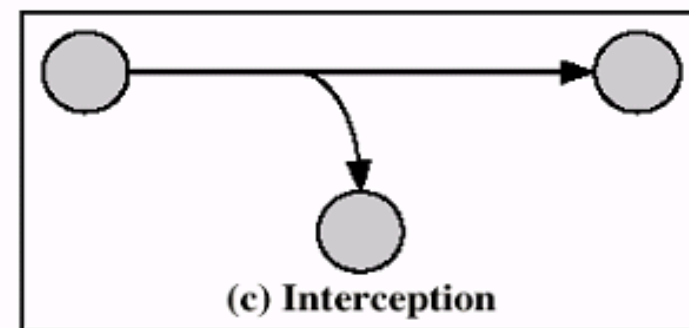
01.基本知识概述：常见攻击小结



正常信息流



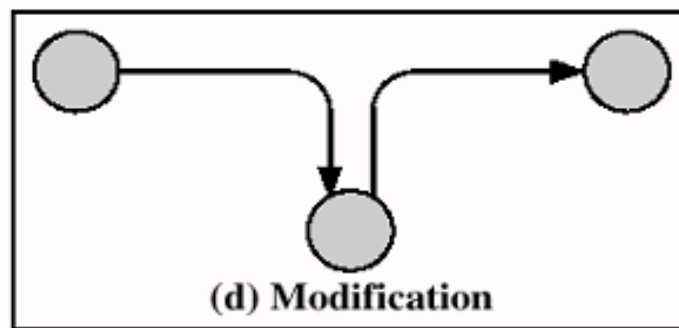
中断 (Interruption) ⇄ 可用性



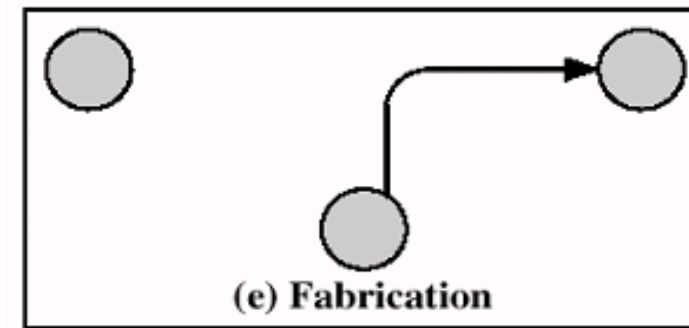
窃听 (Interception) ⇄ 机密性

四种常见攻击：

1. 中断
2. 窃听
3. 修改
4. 伪造



修改 (Modification) ⇄ 完整性



伪造 (Fabrication) ⇄ 认证, 不可否认性

01.基本知识概述：ISO/OSI安全体系结构内容

安全服务

- 在对威胁进行分析的基础上，规定5种标准安全服务：对象认证服务、访问控制安全服务、数据保密性安全服务、数据完整性安全服务、防抵赖性安全服务（非否认性安全服务）。

■ 安全机制

- 基本机制：加密机制、数字签名机制、访问控制机制、数据完整性机制、认证交换机制、防业务流量分析机制、路由控制机制、公证机制等；
- 其它普遍采用的机制：可信功能机制、安全标记机制、事件检测机制、安全审计追踪机制、安全恢复机制等；
- OSI安全体系结构说明了：实现哪些安全服务？应该采用哪些机制？

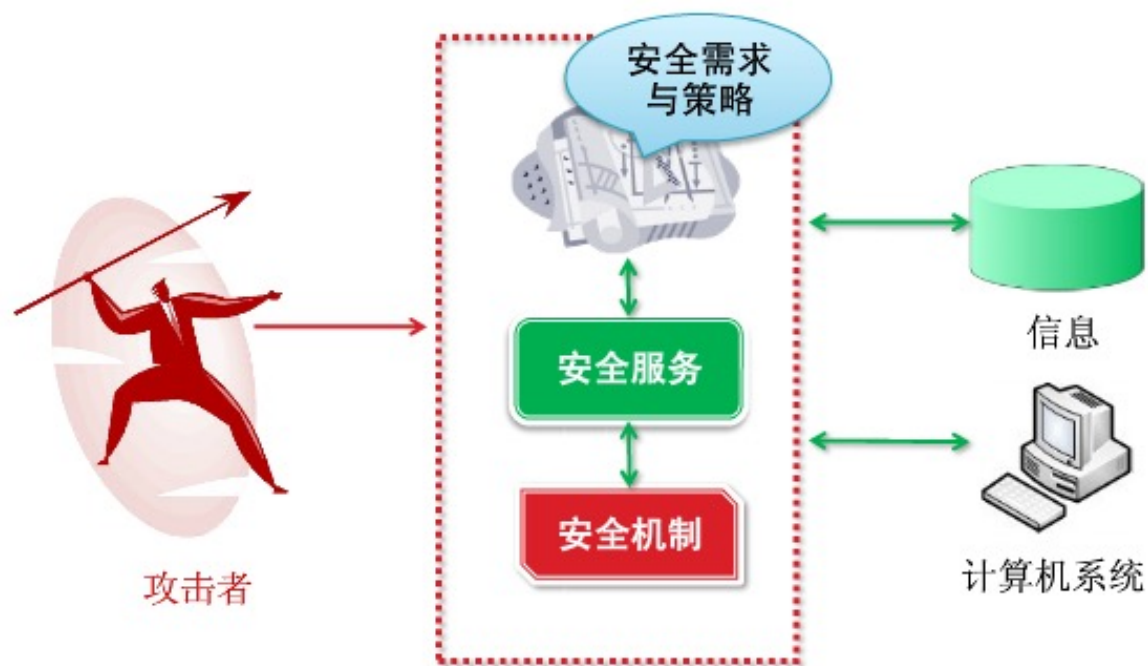
01.基本知识概述：安全服务与安全机制的关系

安全服务与安全机制有着密切的关系。安全服务体现了安全系统的功能；而安全机制则是安全服务的实现。

一个安全服务可以由多个安全机制实现；而一个安全机制也可以用于实现多个安全服务中。

安全服务与安全机制的关系								
安全机制 安全服务	加密	数字 签名	访问 控制	数据 完整性	认证 交换	防业务 流分析	路由 控制	公证
认证	是	是			是			
访问控制		是	是					
机密性	是					是	是	
完整性	是	是		是				
非否认		是		是				是

01.基本知识概述：信息安全保障机制



信息安全风险评估

低级：对于组织（处理能力、功能）、资产、个人造成**有限的轻微**的影响

中级：对于组织（处理能力、功能）、资产、个人造成**严重**的影响

高级：对于组织（处理能力、功能）、资产、个人造成**巨大或灾难性**的影响

01. 基本知识概述：TCSEC

TCSEC标准是计算机系统安全评估的**第一个正式标准**，具有划时代的意义。该准则于1970年由美国国防科学委员会提出，并于1985年12月由美国国防部公布。TCSEC最初只是军用标准，后来延至民用领域。

在TCSEC中，美国国防部按处理信息的等级和应采用的响应措施，将计算机安全从高到低分为：**A、B、C、D四类七个级别，共27条评估准则。**

随着安全等级的提高，系统的可信度随之增加，风险逐渐减少。



A 级	▶	校验级保护
B3 级	▶	安全域，数据隐藏与分层、屏蔽
B2 级	▶	结构化内容保护，支持硬件保护
B1 级	▶	标记安全保护，如System V等
C2 级	▶	有自主的访问安全性，区分用户，如WINDOWS
C1 级	▶	不区分用户，基本的访问控制
D 级	▶	没有安全性可言，例如MS DOS

01.基本知识概述：我国网络安全和信息安全发展史

1986

计算机安全专业委员会

1987

国家信息中心信息安全处

1999

国家计算机网络与信息安全管理协调小组

2001

国务院信息化工作办公室成立网络与信息安全小组

国家在信息安全的法律、规章、原则、方针上都有对应措施，国家信息安全走向正轨

1994

《中华人民共和国计算机信息系统安全保护条例》

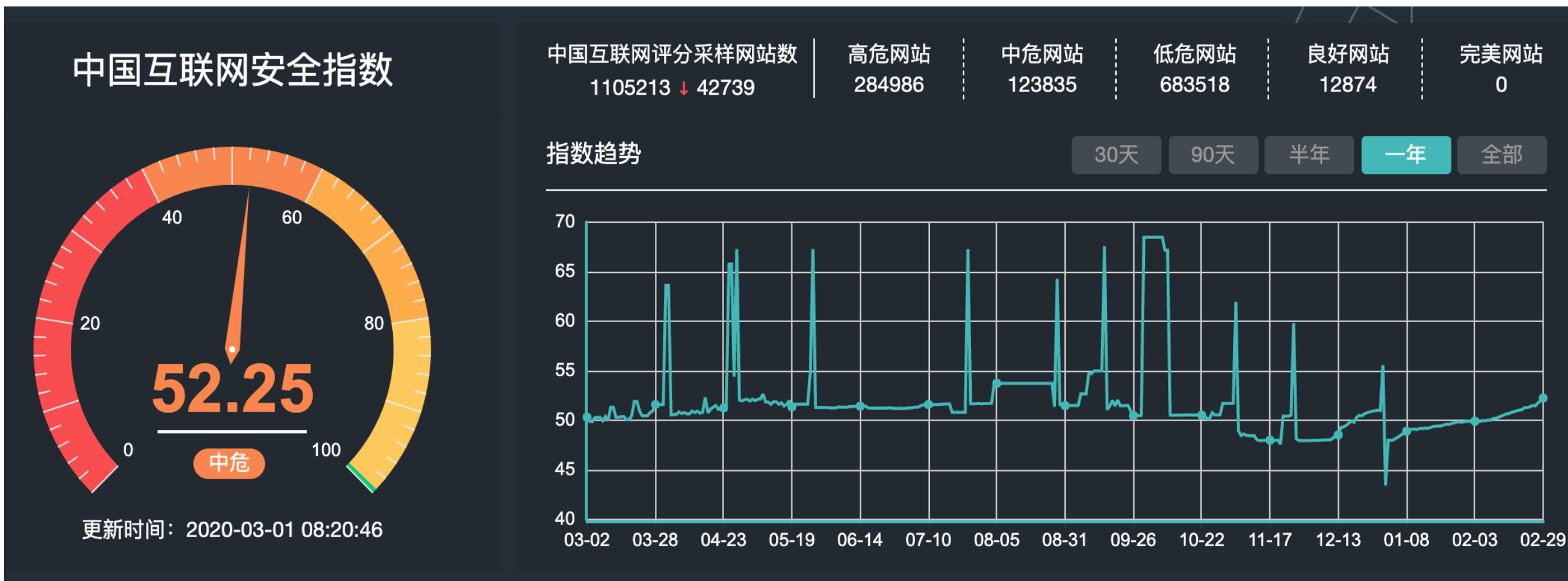
这是我国第一个计算机安全方面的法律，较全面地从法规角度阐述了关于计算机信息系统安全相关的概念、内涵、管理、监督、责任。

2015

《中华人民共和国网络安全法》

2014年是中国接入国际互联网20周年。20年来，中国互联网抓住机遇，快速推进，成果斐然。国家对网络安全的重视日益加强。2015年7月6日《中华人民共和国网络安全法》公布，并向社会公开征求意见。

01.基本知识概述：中国互联网安全指数



国家互联网应急中心: <https://www.cert.org.cn/>



目 录

01

基础知识概述

02

密码学

03

软件系统与安全

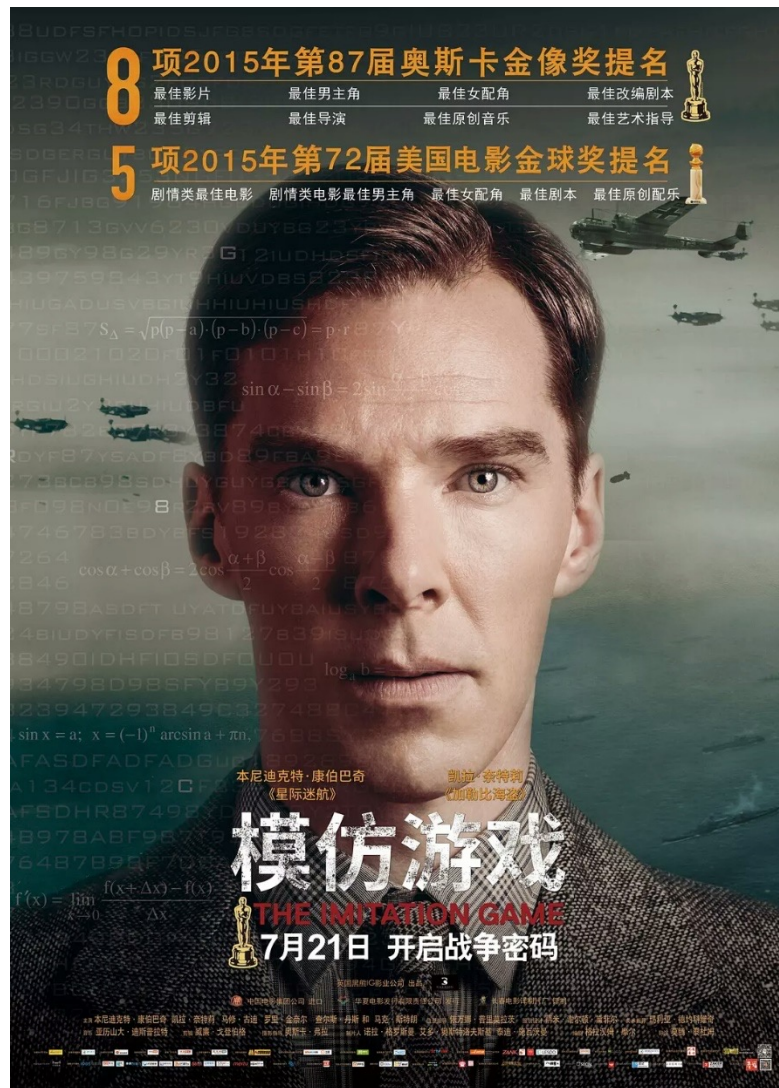
04

网络信息安全

电影《模仿游戏》，2014



电影《模仿游戏》



恩尼格玛机
或“谜”式密码机



改编自安德鲁·霍奇斯编著的传记《艾伦·图灵传》，讲述了“计算机科学之父”艾伦·图灵的传奇人生

聚焦于图灵协助盟军破译德国密码系统“恩尼格玛”（Enigma），从而扭转二战战局的经历

02. 密码学：密码学的定义

密码学(Cryptology)

- 研究编制密码和破译密码的技术科学。
- 数学和计算机科学的分支，包括信息论、计算复杂性理论、统计学、组合学、抽象代数以及数论。

“密码学是关于如何在敌人存在的环境中通信。”

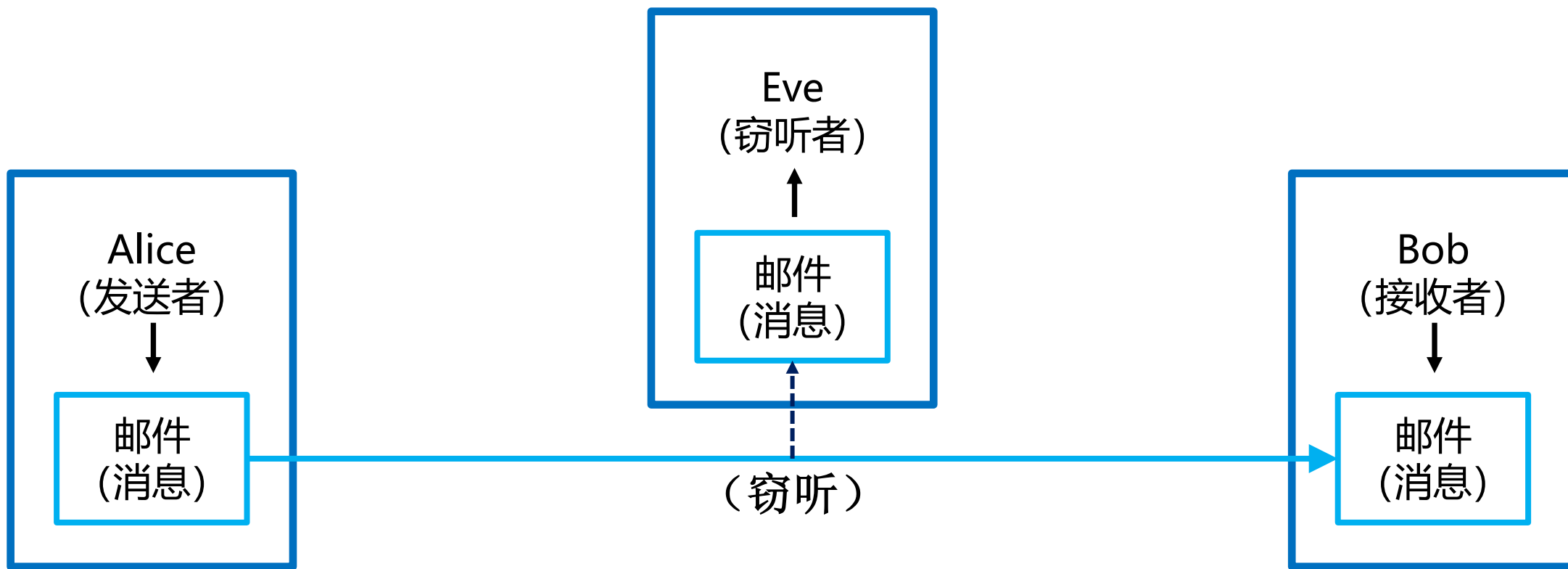
——罗纳德·李维斯特 (Ron Rivest)



罗纳德·李维斯特
美国密码学家，2002年因在公钥密码学
RSA加密算法取得的杰出贡献而获得图灵奖

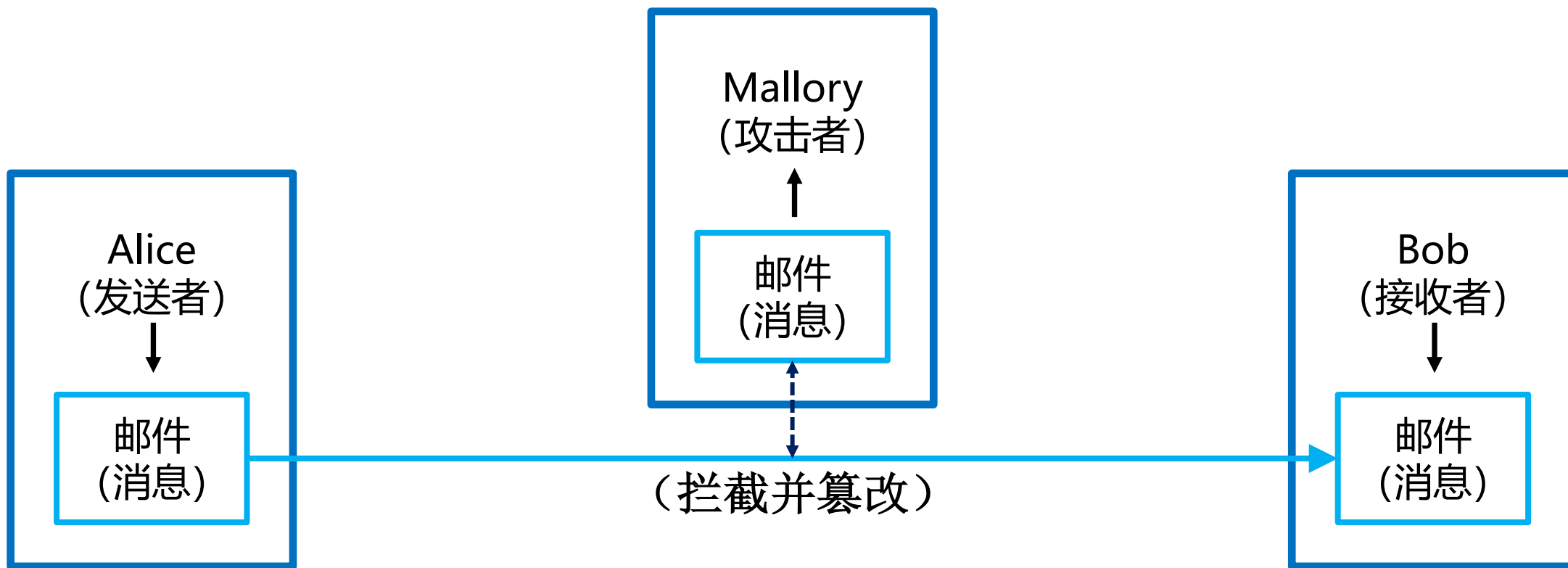
02. 密码学：密码学的意义

密码学保证消息的**保密性 (Confidentiality)**



02. 密码学：密码学意义

密码学保证消息的**完整性 (Integrity)**、**真实性 (Authenticity)**

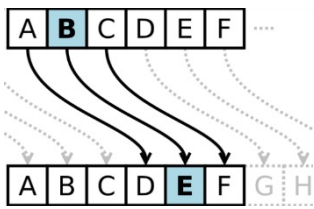


02. 密码学：密码学的发展-古典密码学与近代密码学

公元前5世纪

加密机械

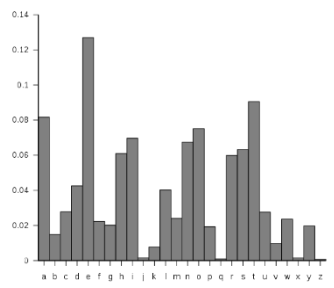
古希腊城邦斯巴达使用的人类历史上最早的加密机械：密码棒 (Scytale)



公元9世纪

频度分析

阿拉伯的密码学家提出解密的频度分析方法



1919

电子加密系统

德国发明家亚瑟·谢尔比乌斯发明了一种能够自动编码的机器恩格玛机 (ENIGMA)



公元前1世纪

替换加密

罗马共和时期凯撒使用的替换加密方式，使用的偏移量就是最早的文字密钥



1553

多表替换

意大利密码学家吉奥万·贝拉索 (Giovan B. Bellaso) 提出根据密钥来决定用哪一行的替换表

古典加密：对称加密的雏形，对称（双方共享密钥）
现实：古典密码都已经被破解

02. 密码学：密码学的发展-现代密码学

现代密码学开端： 公钥密码诞生

把密钥分为加密的公钥和解密的私钥。

优势：不需要双方提前共享密钥

安全性：从公钥难以推算出私钥

1976

Diffie-Hellman密钥交换 (图灵奖2015)

斯坦福大学惠特菲尔德·迪菲 (Bailey Diffie) 和马丁·赫尔曼 (Martin Hellman) 提出的第一个密钥交换算法



1986

多方安全计算 (图灵奖2000)

普林斯顿大学的姚期智提出的在无可信第三方情况下，能够安全地进行多方协同计算的理论框架

1975

数据加密标准 (DES)

美国国家标准局将Data Encryption Standard (DES)颁布为国家标准

1977

RSA算法 (图灵奖2002)

麻省理工学院的罗纳德·李维斯特 (Ron Rivest) 阿迪·萨莫尔 (Adi Shamir) 和伦纳德·阿德曼 (Leonard Adleman) 提出了第一个比较完善的公钥密码体制



姚期智 Andrew Yao

02. 密码学概述：密码学的发展-现代密码学

2005

容错学习问题（哥德尔奖2018）

由 Oded Regev 在2005年提出。求解LWE问题的时间开销是指数级的，即使是对量子计算机也没有任何帮助，故LWE困难性被用作创建公钥密码系统



Oded Regev

2013

不可区分混淆 (iO) -密码学皇冠上的明珠

是最有可能实现的安全混淆器。混淆后的程序与混淆前功能一样，并且无法从混淆代码中提取出任何有效信息（密钥、模型等）。iO可以用来保护机器学习的模型和算法。

2005

基于属性的加密 (ABE)

最先由Waters提出，是一种公钥加密方案。实现了加密数据的细粒度访问控制，即数据拥有者可以指定谁可以访问加密的数据，数据拥有者对数据具有完全的控制权

2009

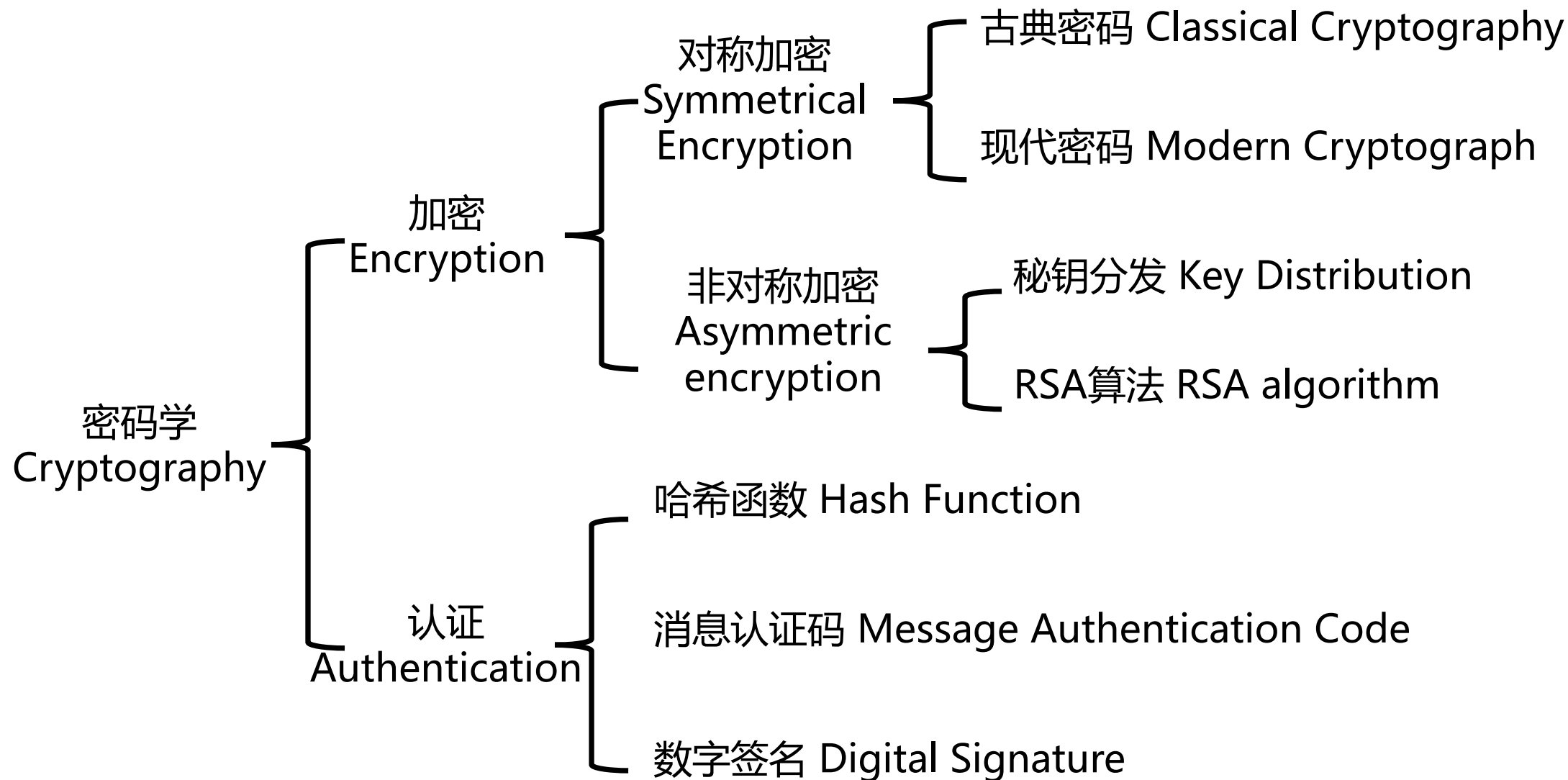
全同态加密 (FHE)

IBM的Craig Gentry提出的同态加密算法。可以在没有密钥的情况下，把密文任意组合形成新的密文，并且新的密文可以完美的被还原成明文



Craig Gentry

02. 密码学：密码学的分类



02. 密码学：密钥加密

明文 (Cleartext)

- 未经加密保护，可轻易解读的信息

加密算法 (Encryption Algorithms)

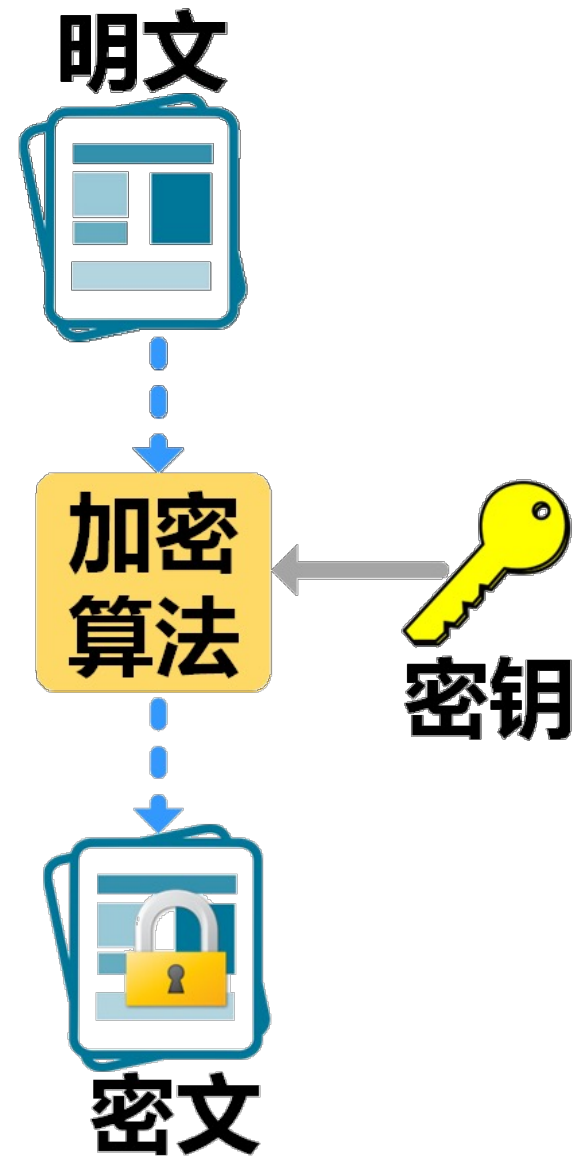
- 将输入的明文转换为密文的算法

密钥 (Secret Keys)

- 通信收、发双方共享的秘密信息
- 用于信息加密、解密

密文 (Ciphertext)

- 加密算法的输出
- 安全性：不经解密，他人难以解读密文内容



02. 密码学：密钥解密

解密算法 (Decryption Algorithms)

- 将**密文**转换成**明文**的算法

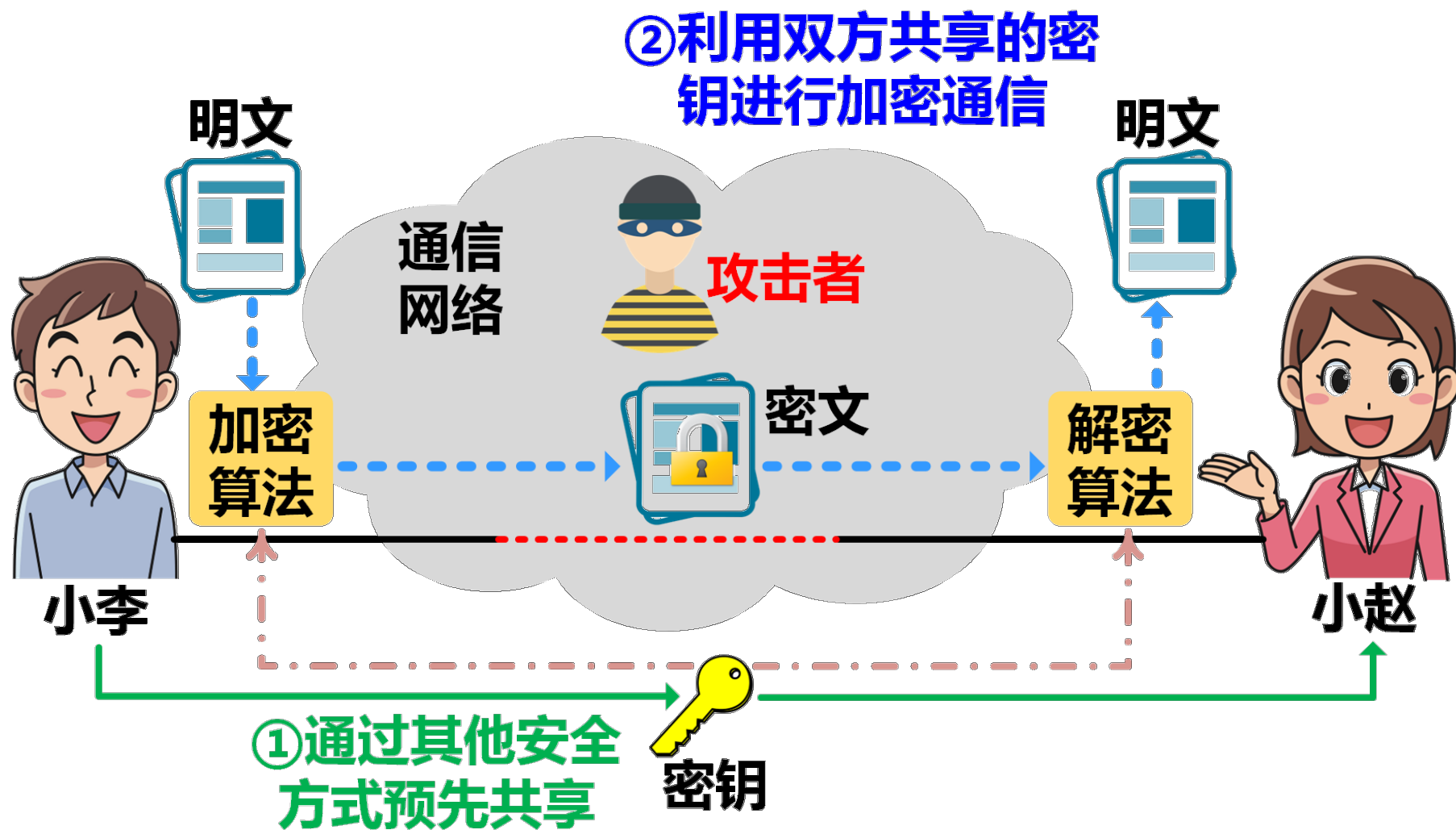
对称加密 (Symmetric Cryptograph)

- 加密、解密使用相同的密钥



02. 密码学：密钥系统

对称加密中，发送方需将密钥提前共享给接收方



02. 古典密码学：最早的密码——密码棒

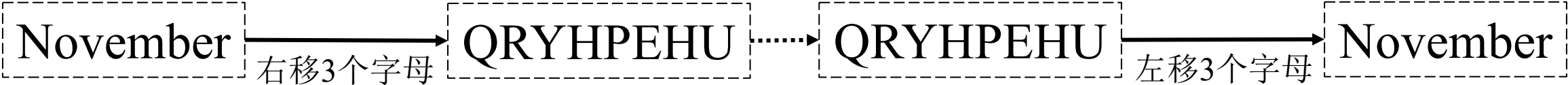
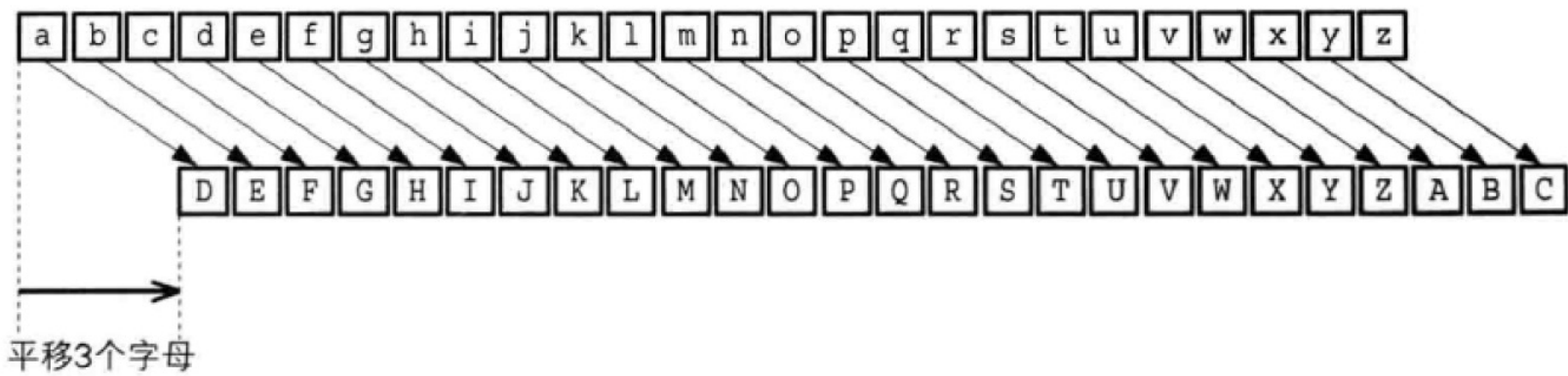
公元前5世纪

密码棒（Scytale，希腊语）

- 古希腊的斯巴达人最早使用一根叫 Scytale 的棍子进行加密
- 送信人先绕棍子卷一张纸条，然后把要写的信息打纵写在上面，接着打开纸送给收信人。
- 如果不知道棍子的粗细是不能解密里面的内容的



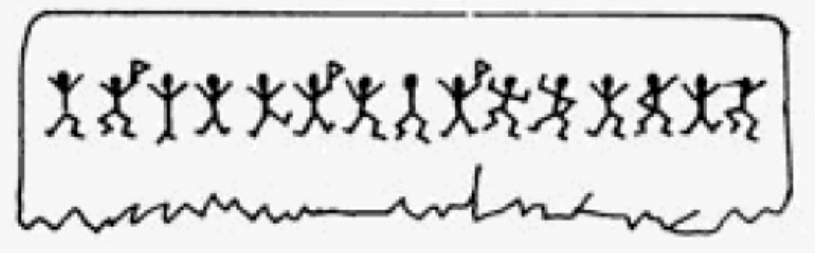
凯撒密码



02. 古典密码学：单表替换密码

单表替换密码

- 相比于凯撒密码使用了随机排列
- 《福尔摩斯 跳舞的小人》
- “的确是一件很难看懂的作品，”
福尔摩斯说，“乍一看就象孩子们开的玩笑，在纸上横着画了些在跳舞的奇形怪状的小人。”



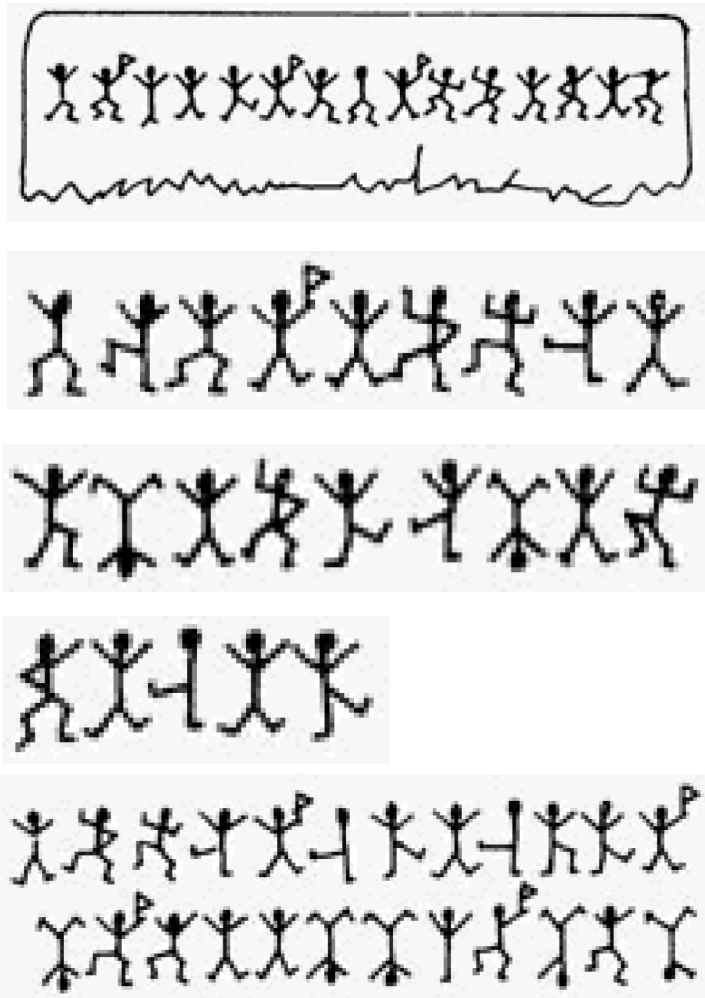
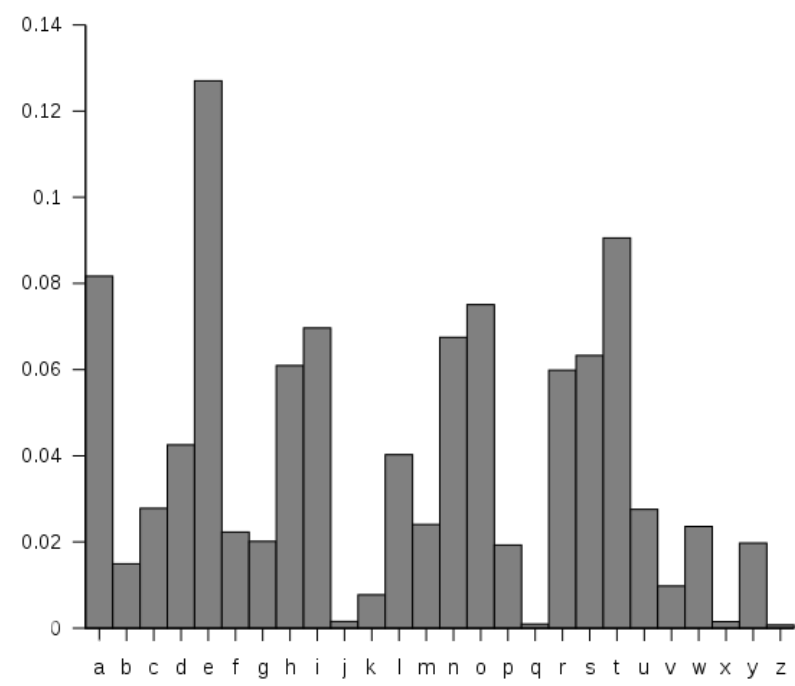
a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓
W	Y	H	F	X	U	M	T	J	V	S	G	E	N	B	R	D	Z	L	Q	A	P	C	O	K	I

A	B	C	D	E	F	G	H	I	J	K	L	M
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓
N	O	P	Q	R	S	T	U	V	W	X	Y	Z
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓
↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓	↓

02. 古典密码学：单表替换密码的破解

破译方法：频率分析

- 公元前9世纪阿拉伯的密码学家提出解密的频度分析方法



“在交给我的第一张纸条上那句话很短，我只能稍有把握假定人代表E。你们也知道，在英文字母中E最常见，它出现的次数多到即使在一个短的句子中也是最常见的”

“大致说来，字母按出现次数排列的顺序是T, A, O, I, N, S, H, R, D, L; 但是T, A, O, I, 出现的次数几乎不相上下”

“当中有三个别的字母的组合很可能就是ELSIE（埃尔茜）这个名字。我一检查，发现这个组合曾经三次构成一句话的结尾。这一来我就找出了L、S和I”

02. 古典密码学：多表替换密码

1858年

多表替换密码（维吉尼亚密码）

- 16世纪意大利密码学家吉奥万·贝拉索(Giovan B. Bellaso)提出根据密钥来决定用哪一行的替换表
- $M[i] = \text{Table}[P[i]][S[i]]$

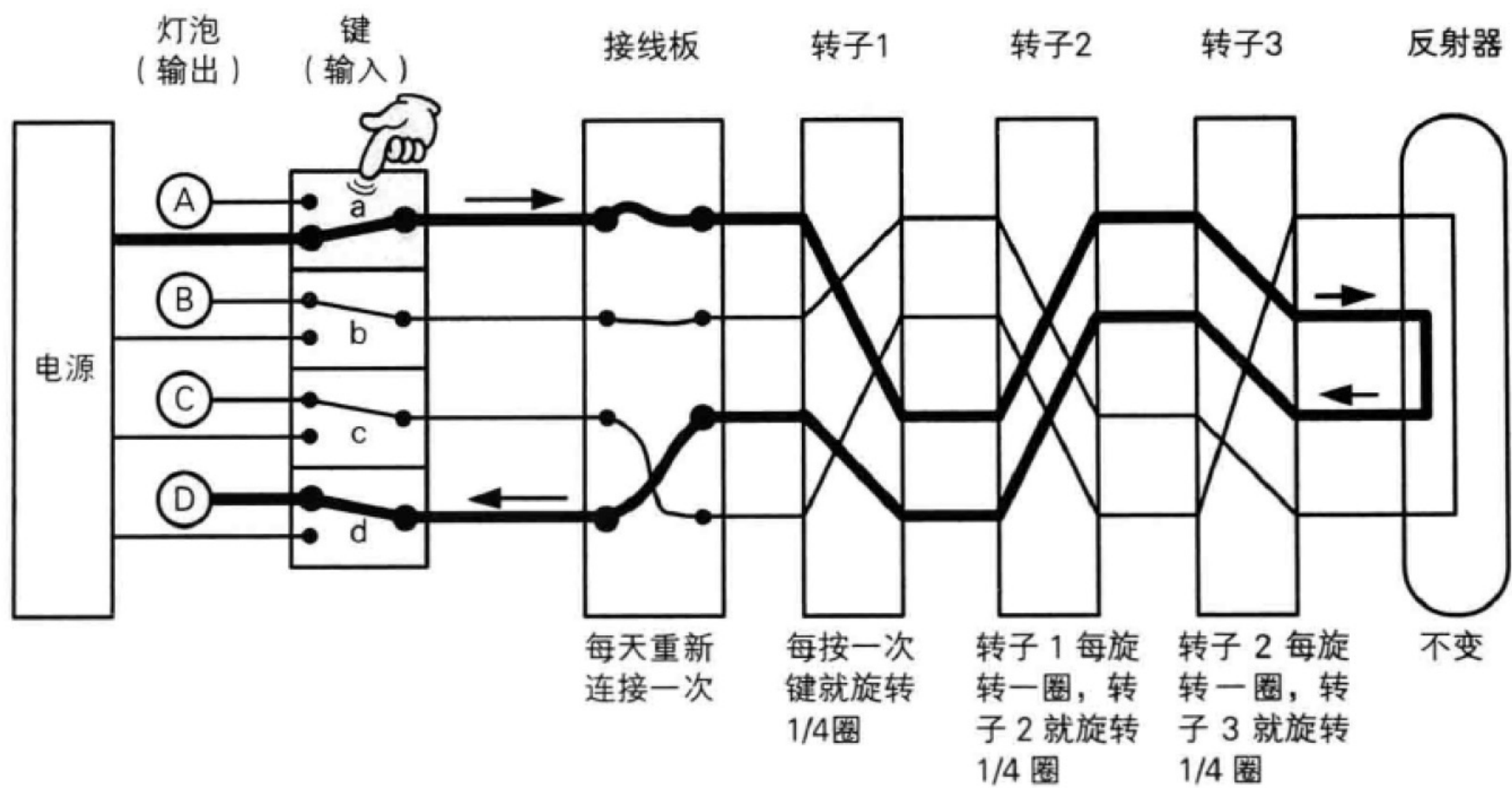
明文: A T T A C K A T D A W N
密钥: L E M O N L E M O N L E
密文: L X F O P V E F R N H R

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

02. 古典密码学：恩格玛机

1919年

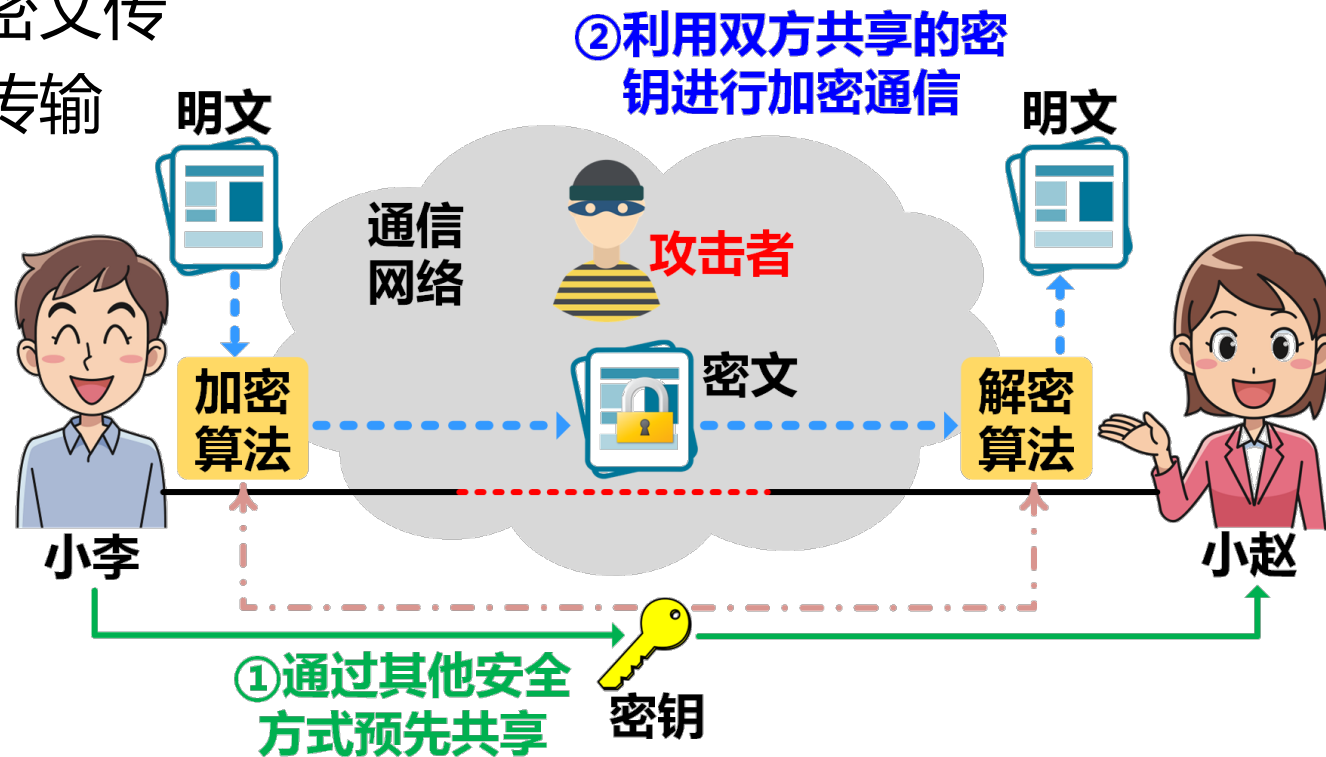
恩格玛机（Enigma）



02. 现代密码学：密码设计的变革

对称密码体制的缺陷

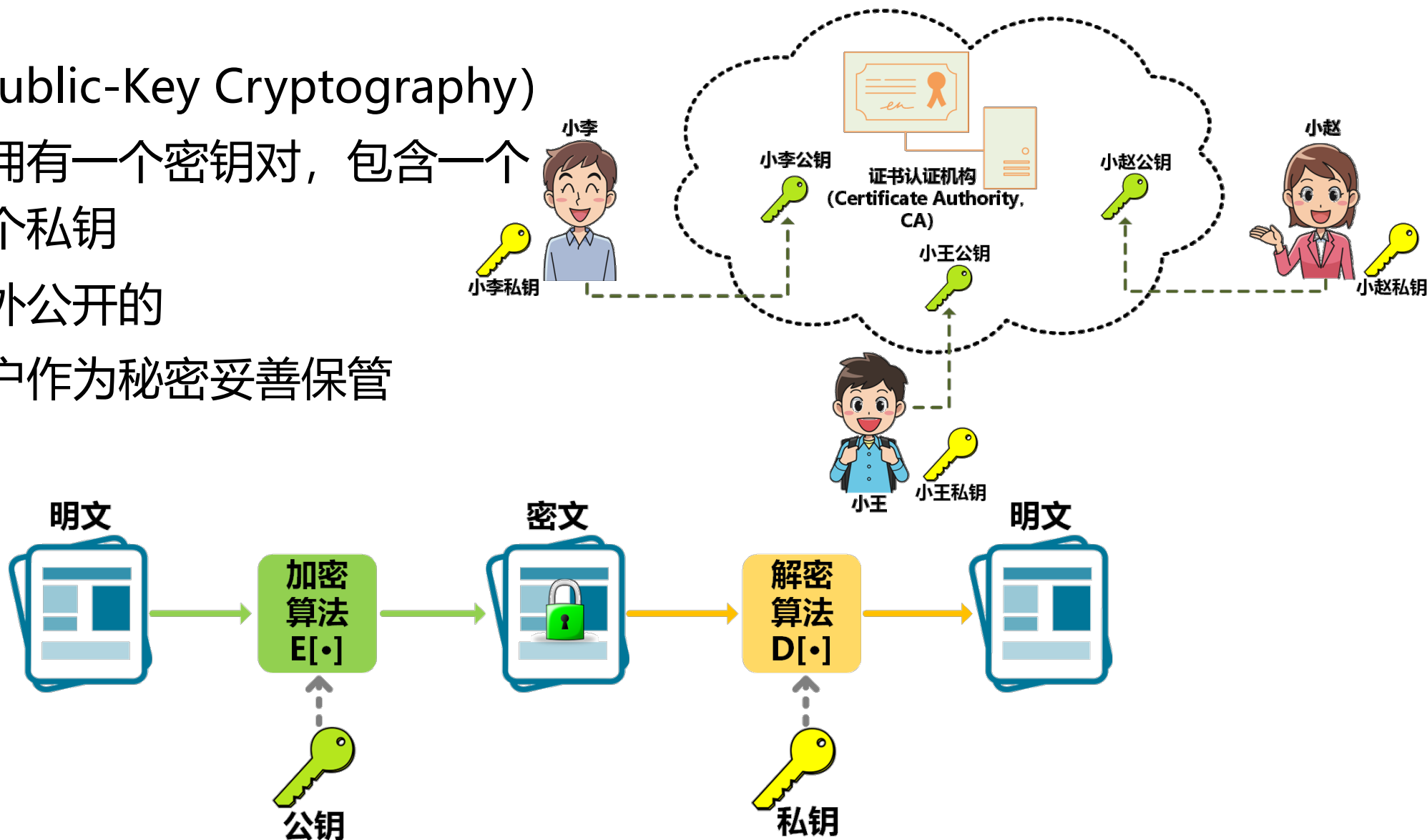
- 加密密钥与相应的解密密钥相同
- 消息的发送方和接收方必须在密文传输之前通过安全信道进行密钥传输
- 存在潜在的安全风险



02. 现代密码学：公钥加密系统

公钥加密 (Public-Key Cryptography)

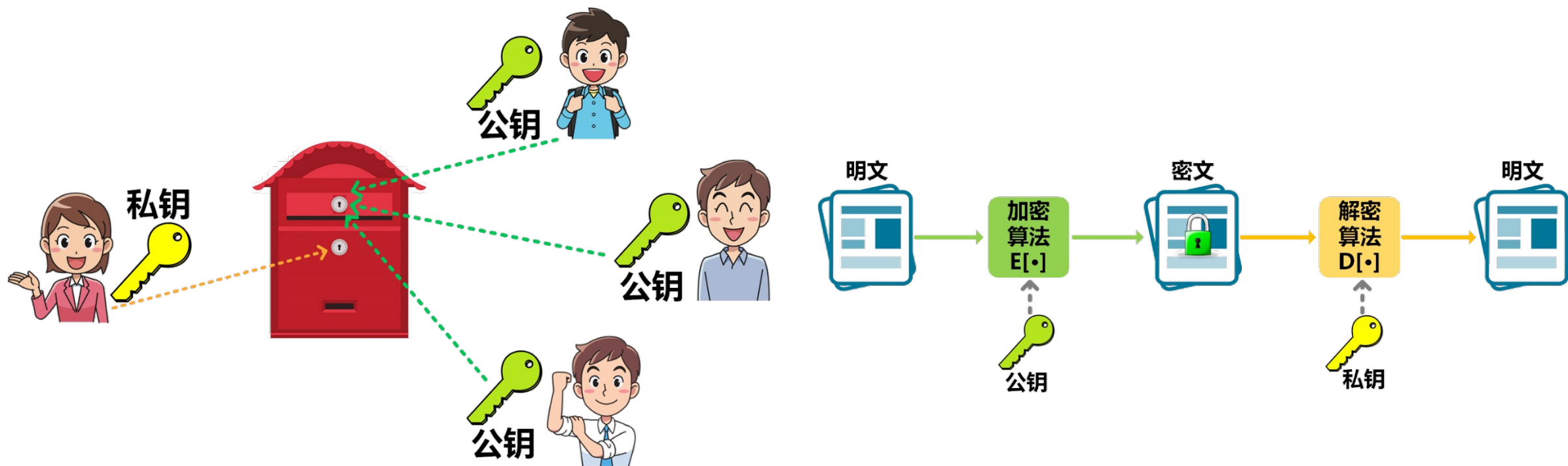
- 每个用户拥有一个密钥对，包含一个公钥，一个私钥
- 公钥是对外公开的
- 私钥由用户作为秘密妥善保管



02. 现代密码学：公钥加密系统

非对称加密 (Asymmetric Cryptography)

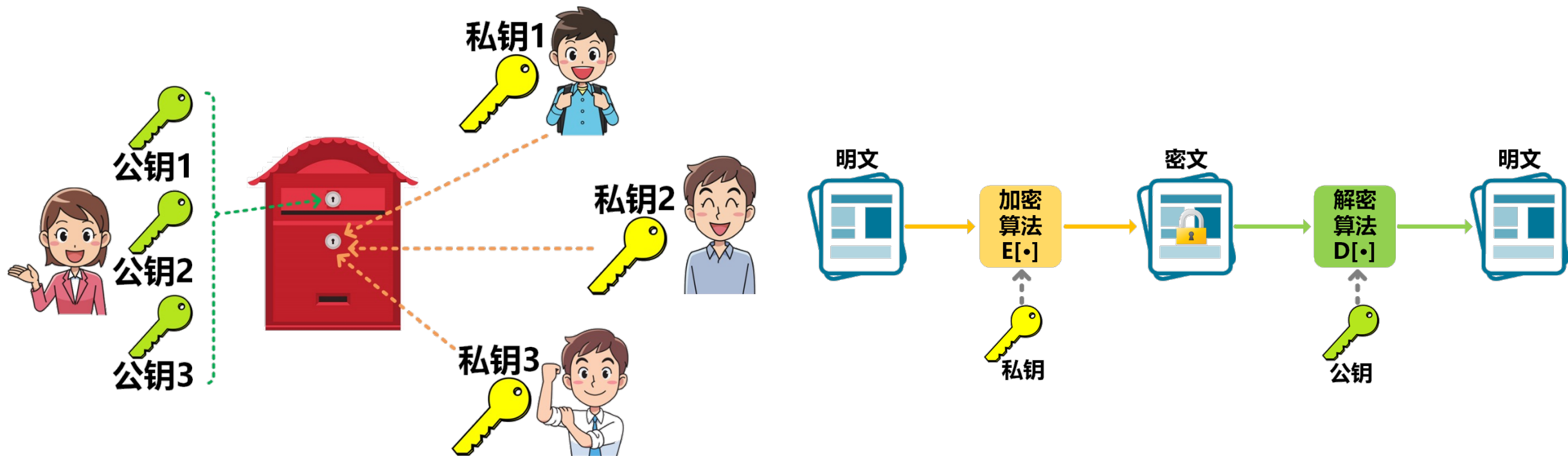
- **公钥加密**，则须用**私钥解密**
- 任何人可以使用某用户的公钥生成密文，仅该用户才能使用私钥进行解密



02. 现代密码学：公钥加密系统

非对称加密 (Asymmetric Cryptography)

- 私钥加密，则须用公钥解密
- 某用户使用自己的私钥生成密文，则任何人均能使用该用户的公钥进行解密



02. 现代密码学：安全通信

利用接收者的公钥对信息进行加密

常用公钥算法：RSA算法、椭圆曲线算法（如国密SM2）

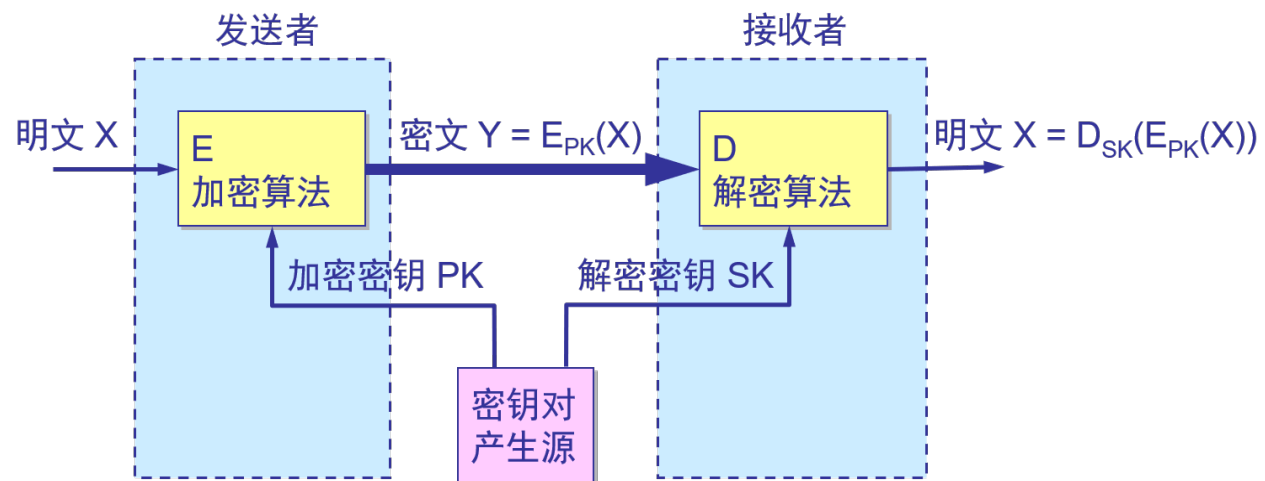


02. 现代密码学：公开密钥密码体制

公开密钥密码体制使用**不同的加密密钥与解密密钥**，是一种“由已知加密密钥推导出解密密钥在计算上是不可行的”密码体制。

两个主要用途：一是解决常规密钥密码体制的密钥分配问题，另一是用于数字签名。

最著名的体制：**RSA 体制**，它基于数论中大数分解问题的体制，由美国三位科学家 Rivest, Shamir 和 Adleman 于 1976 年提出并在 1978 年正式发表的。



加密密钥(即公开密钥) PK、加密算法 E 和解密算法 D 都是公开的，只有解密密钥(即秘密密钥) SK 是需要保密的

虽然秘密密钥 SK 是由公开密钥 PK 决定的，但却不能根据 PK 计算出 SK。

02. 现代密码学： RSA算法

生成密钥对

- 选取两质数 p, q , 令 $N = p \times q$.
- $\phi(N)$ 为 欧拉函数, 对两质数 p, q , $\phi(pq) = (p - 1)(q - 1)$.
- 选择整数 E , 与 $\phi(N)$ 互质.
- 用欧几里得算法计算 $D = E^{-1} \bmod \phi(N)$.
- E 和 D 为模 $\phi(N)$ 的乘法逆元.
- 加密解密表达式成立.
- Eve计算密钥等于求解**质因数分解问题**, 目前算法复杂度为指数级.

$$N = p \times q$$



$$\phi(N) = (p - 1)(q - 1)$$



$$\gcd(E, \phi(N)) = 1, D = E^{-1} \bmod \phi(N)$$



$$E \times D \bmod \phi(N) = 1$$



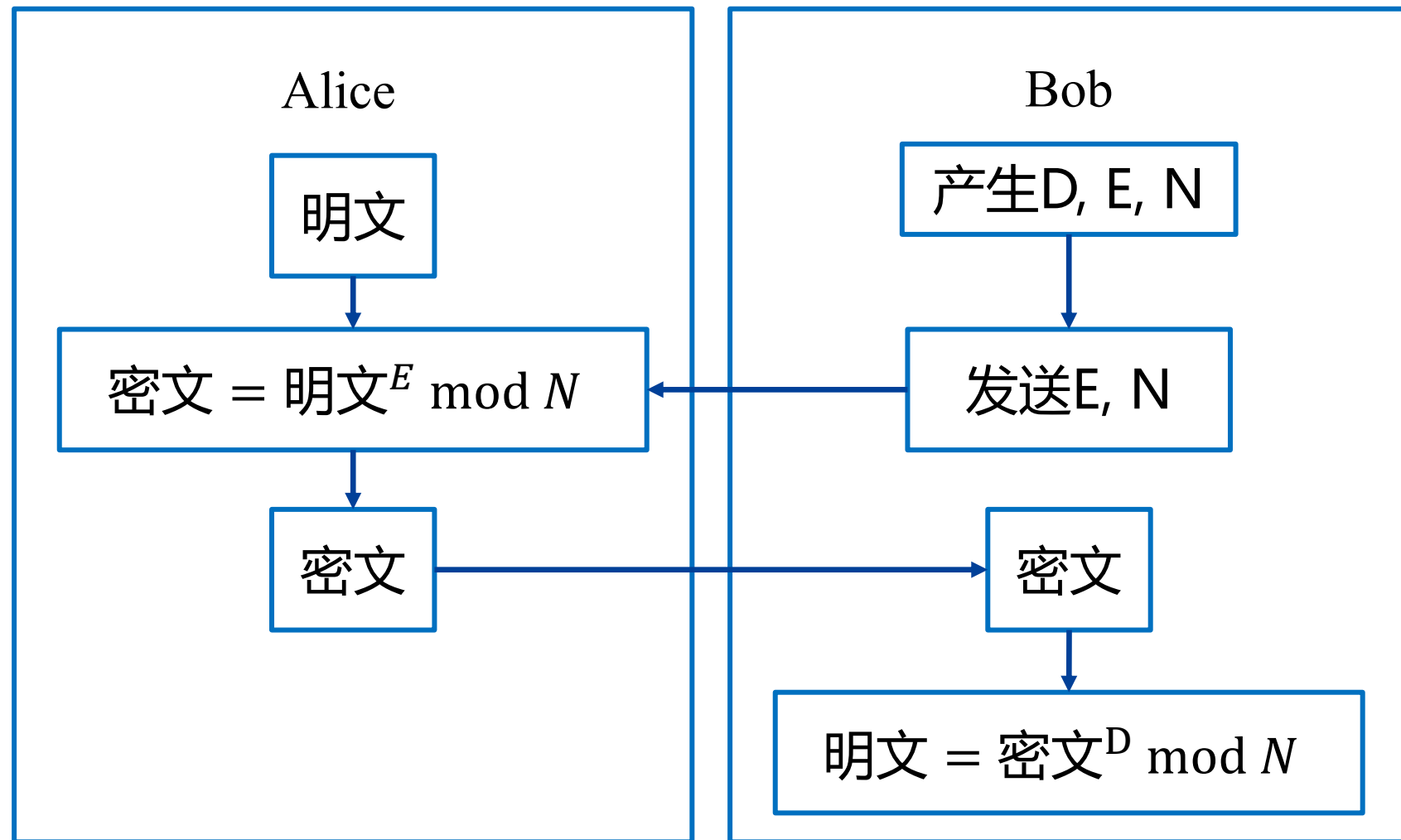
$$M^{E \times D} \bmod N = M \bmod N$$

02. 现代密码学： RSA算法

1978年

公钥密码： RSA算法

- 公钥： E和N
- 私钥： D和N
- Bob将公钥发给Alice
- Alice用公钥加密
- Alice发送密文
- Bob用私钥解密



03. 现代密码学： RSA算法

利用RSA加密第一步需将明文数字化，并取长度小于 $\log_2 n$ 位的数字作明文块。

加密算法： $c = E(m) \equiv m^e \pmod{n}$

解密算法： $D(c) \equiv c^d \pmod{n}$

RSA实例1

- 假设 $p=3$ 、 $q=11$ ，计算 $n=pq=33$ ， $\varphi(n)=(p-1)(q-1)=20$
- 随机选择整数 e ，满足 $1 < e < \varphi(n)=20$ ， $\gcd(e, \varphi(n))=1$ ，这里选择 $e=7$
- 解方程 $de \equiv 1 \pmod{\varphi(n)}$ ，即 $7d \equiv 1 \pmod{20}$ ，得 $d=3$ 。密钥对即为： $(7, 33)$ ， $(3, 33)$
- 假设明文 $m=4$ ，加密： $4^7 = 16384 \pmod{33} = 16$ ，解密： $16^3 = 4096 \pmod{33} = 4$

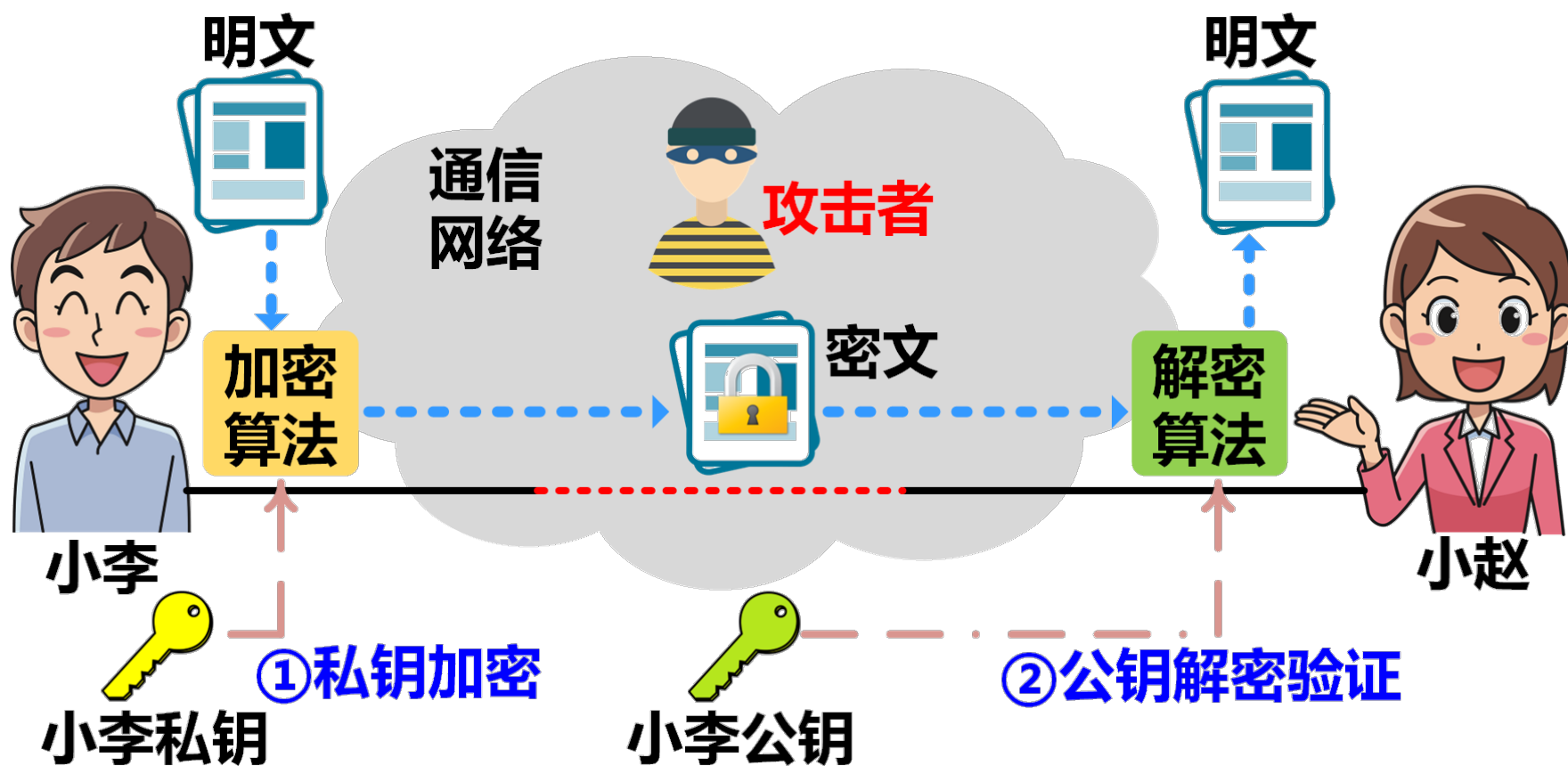
RSA实例2

- 选素数 $p=47$ 和 $q=71$ ，计算 $n=pq=3337$ ， $\varphi(n)=(p-1)(q-1)=3220$
- 选择 $e=79$ ，求得私钥 $d \equiv e^{-1} \pmod{3220} = 1019$ ，公开 $n=3337$ 和 $e=79$
- 现要发送明文 688，计算： $688^{79} \pmod{3337} = 1570$
- 收到密文 1570 后，用私钥 $d=1019$ 进行解密： $1570^{1019} \pmod{3337} = 688$

02. 现代密码学：身份验证

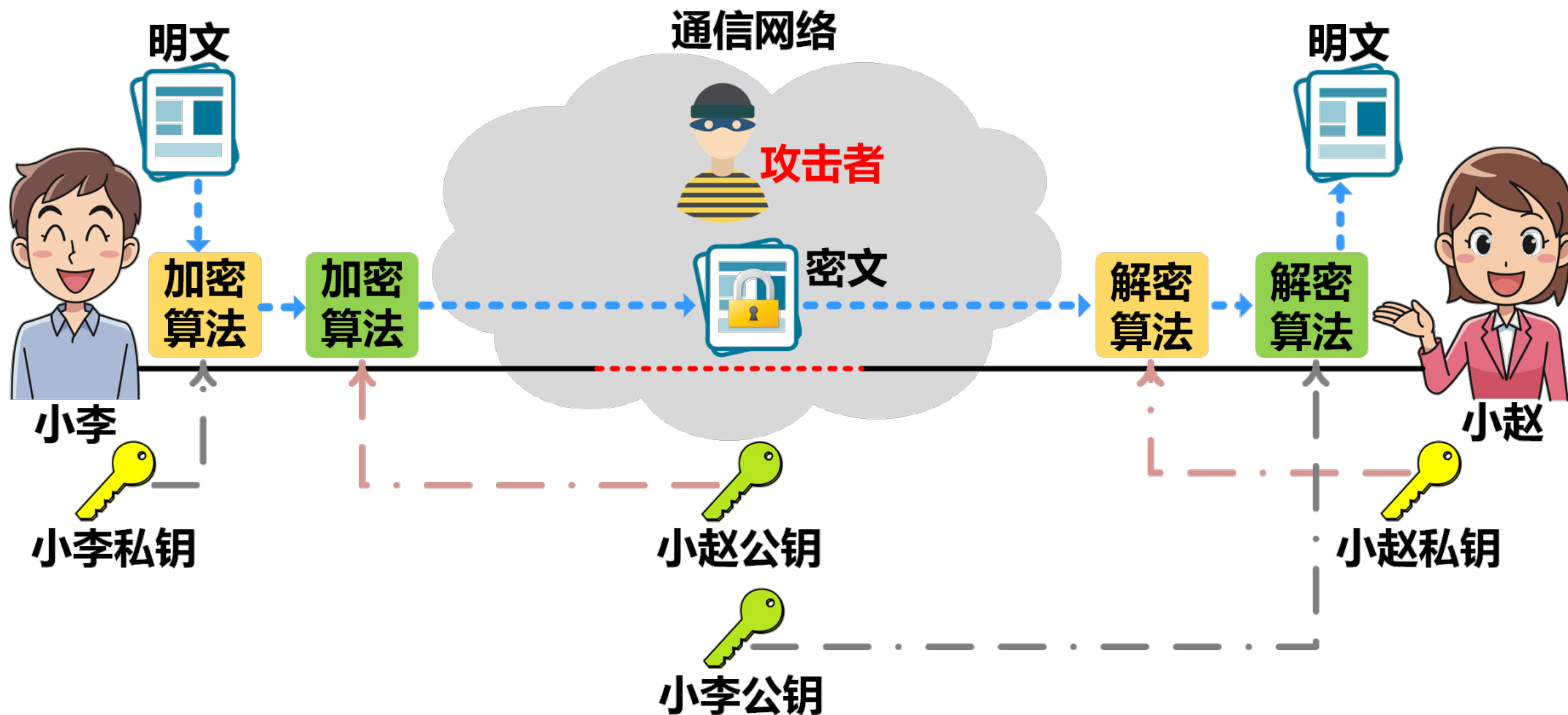
小李如何向小赵证明自己的身份？

- 使用自己的私钥加密一段信息



02. 现代密码学：保障信息安全

如何保障通信的**保密性**和信息的**完整性**？



02. 现代密码学：潜在问题

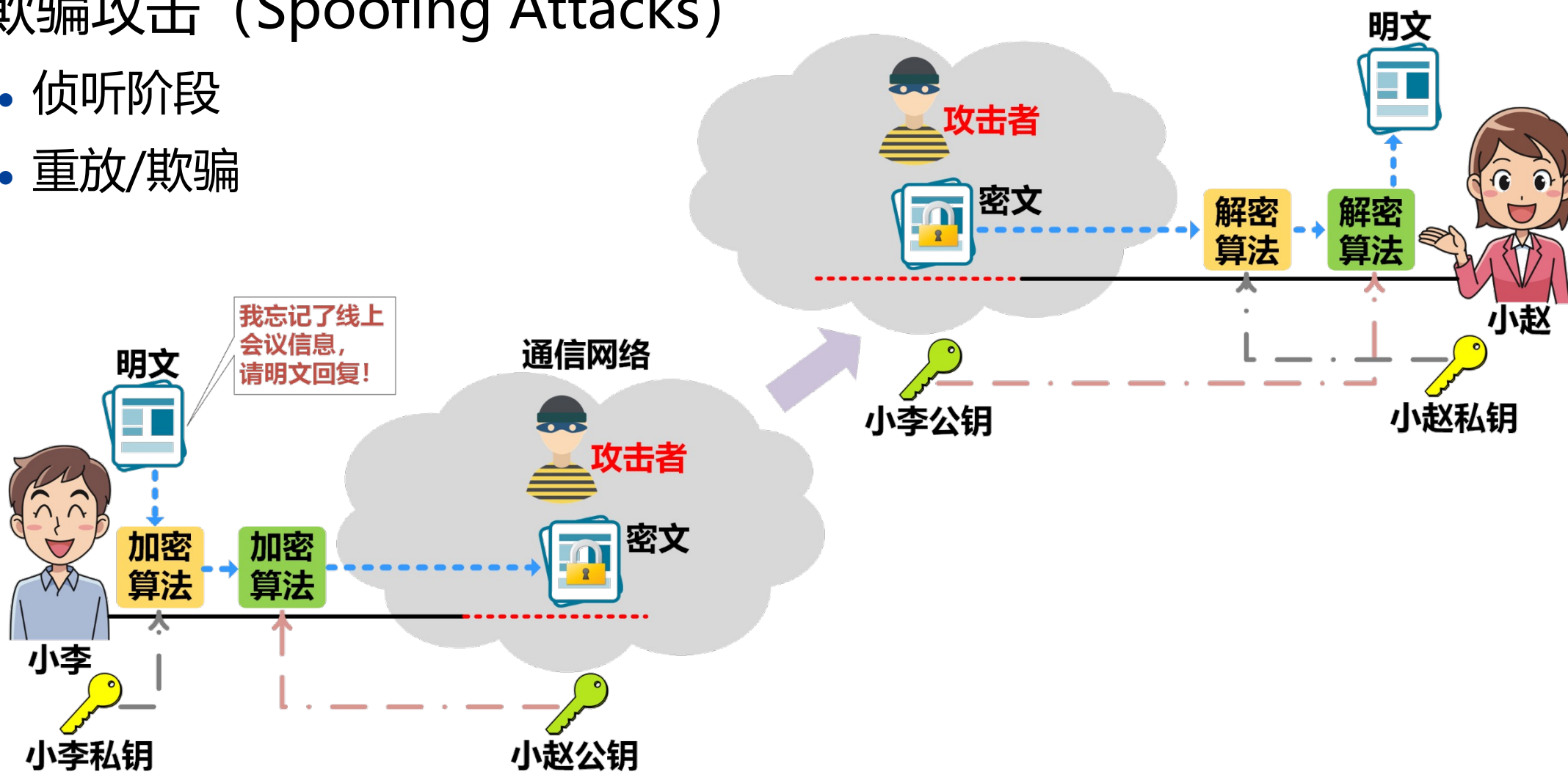
目前，我们讨论的公钥系统通信方案采用双重加密，即发送者用自己的私钥、接收者的公钥两次对明文进行加密。你觉得这样的方案，是否存在问题？

- ☐ A 不存在任何问题
- ☒ B 对明文双重加密的算力开销可能过大
- ☒ C 可能仍存在安全漏洞，有网络攻击风险

02. 现代密码学：欺骗攻击的风险

欺骗攻击 (Spoofing Attacks)

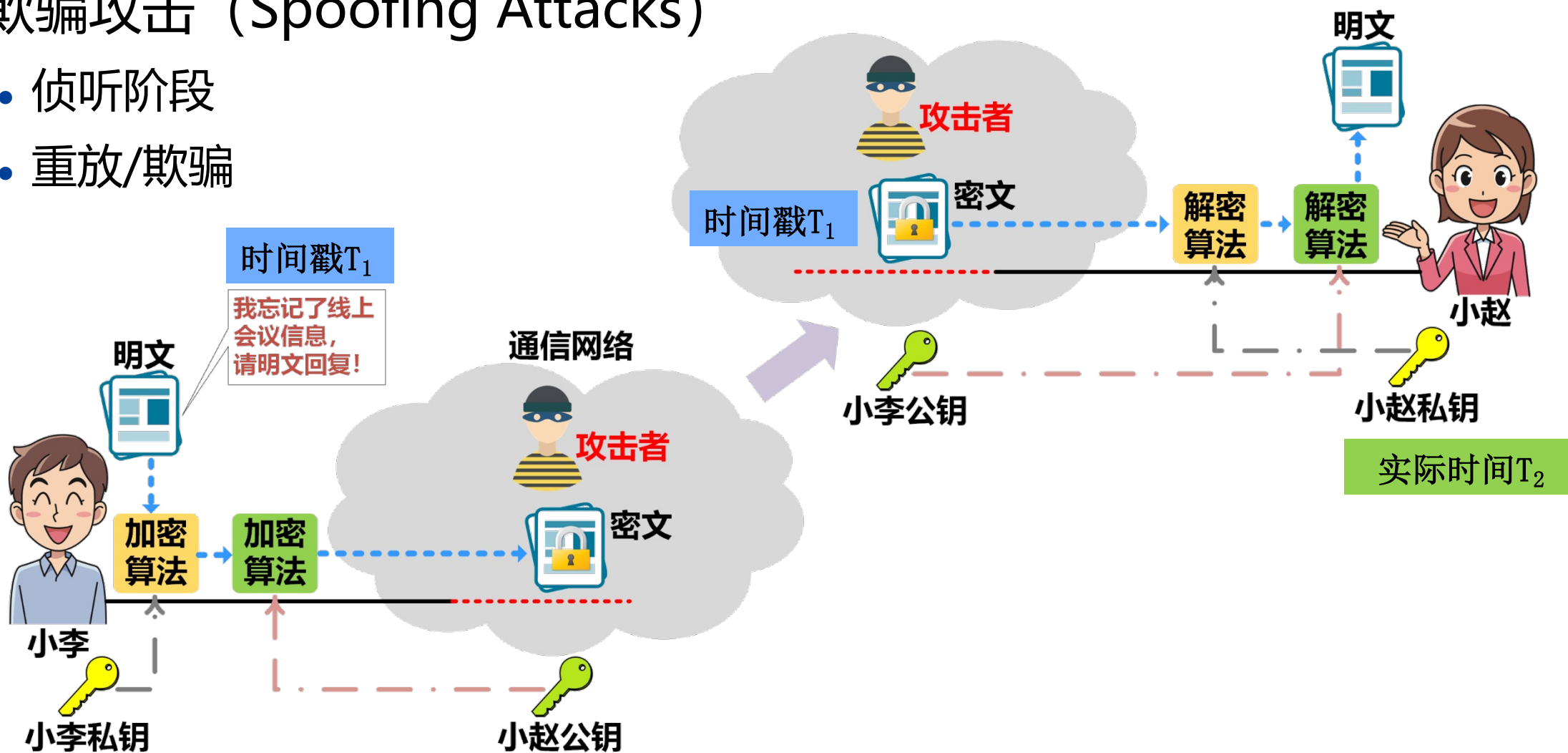
- 侦听阶段
- 重放/欺骗



02. 现代密码学：利用时间戳防范欺骗攻击

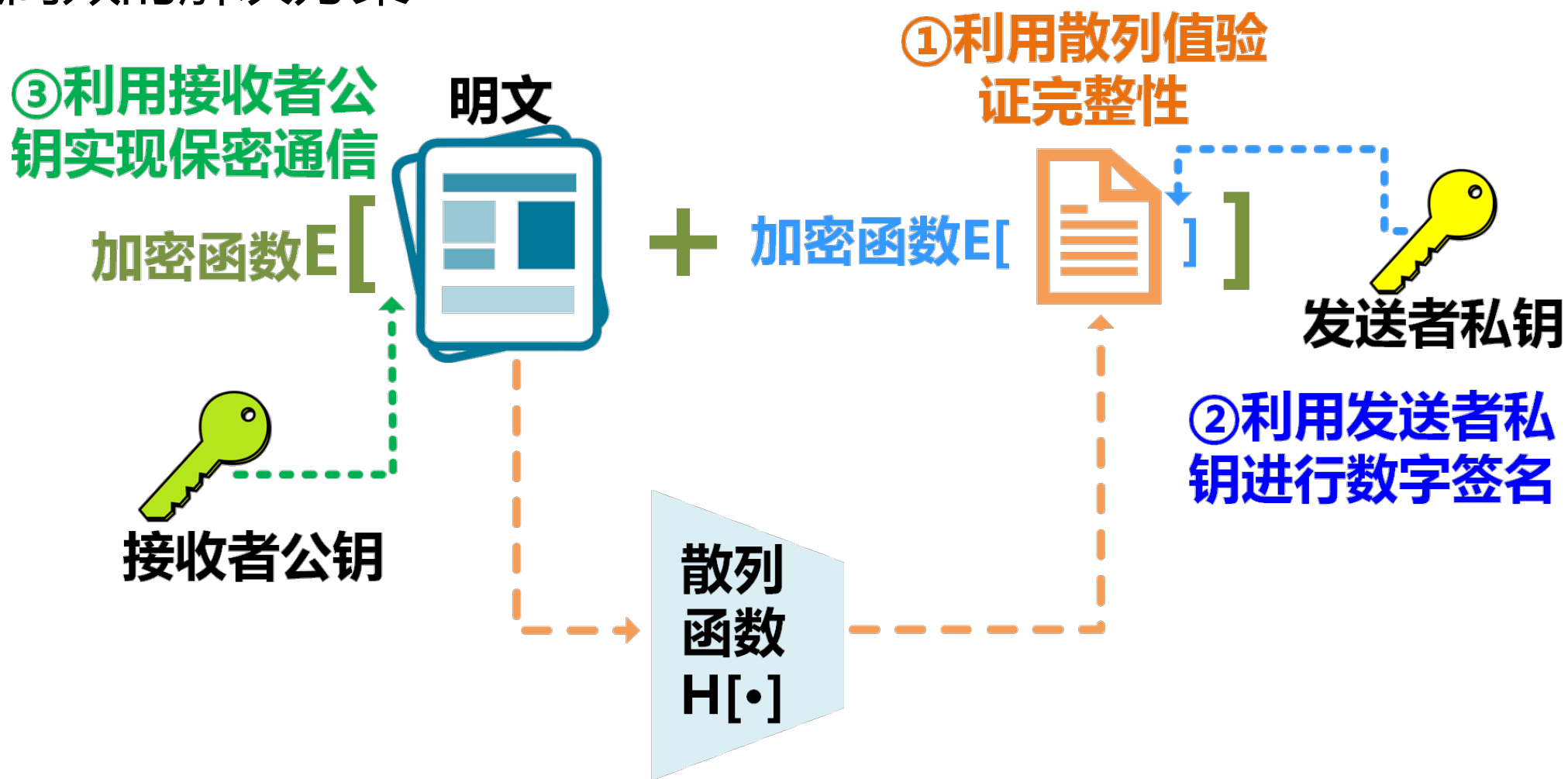
欺骗攻击 (Spoofing Attacks)

- 侦听阶段
- 重放/欺骗



02. 现代密码学：数字签名

更高效的解决方案



02. 现代密码学：中国现代密码学

王小云（清华大学教授、中科院院士）

- 提出了密码哈希函数的碰撞攻击理论，即模差分比特分析法，破解了包括MD5、SHA-1在内的5个国际通用哈希函数算法的强碰撞性，导致工业界几乎所有软件系统中MD5和SHA-1哈希函数逐步淘汰

碰撞攻击

- 找到两个信息块，两者的哈希值相同



王小云教授

2019未来科学大奖在京揭晓，王小云成首位女性获奖者



目 录

01

基础知识概述

02

密码学

03

软件系统与安全

04

网络信息安全

03.软件系统安全：恶意软件分类

90 年代末，恶意软件（或恶意代码）被定义为经过存储介质和网络进行传播，从一台计算机系统到另外一台计算机系统，未经授权认证破坏计算机系统完整性的程序或代码。

恶意软件（或恶意代码）两个显著的特点是：非授权性和破坏性

- 二进制文件
- 脚本语言
-

恶意软件（或恶意代码）包括：计算机病毒(Computer Virus)、蠕虫(Worms)、特洛伊木马(Trojan Horse)、逻辑炸弹(Logic Bombs)、后门(Backdoor)、用户级RootKit、核心级RootKit、脚本恶意代码(Malicious Scripts)、僵尸 (Zombie)、间谍软件、网络钓鱼软件和恶意ActiveX 控件等

03.软件系统安全：恶意软件行为

删除敏感信息

作为网络传播的起点

监视键盘

收集你的相关信息

获取屏幕

在系统上执行指令/程序

窃取文件，如文档/财务/技术/商业机密

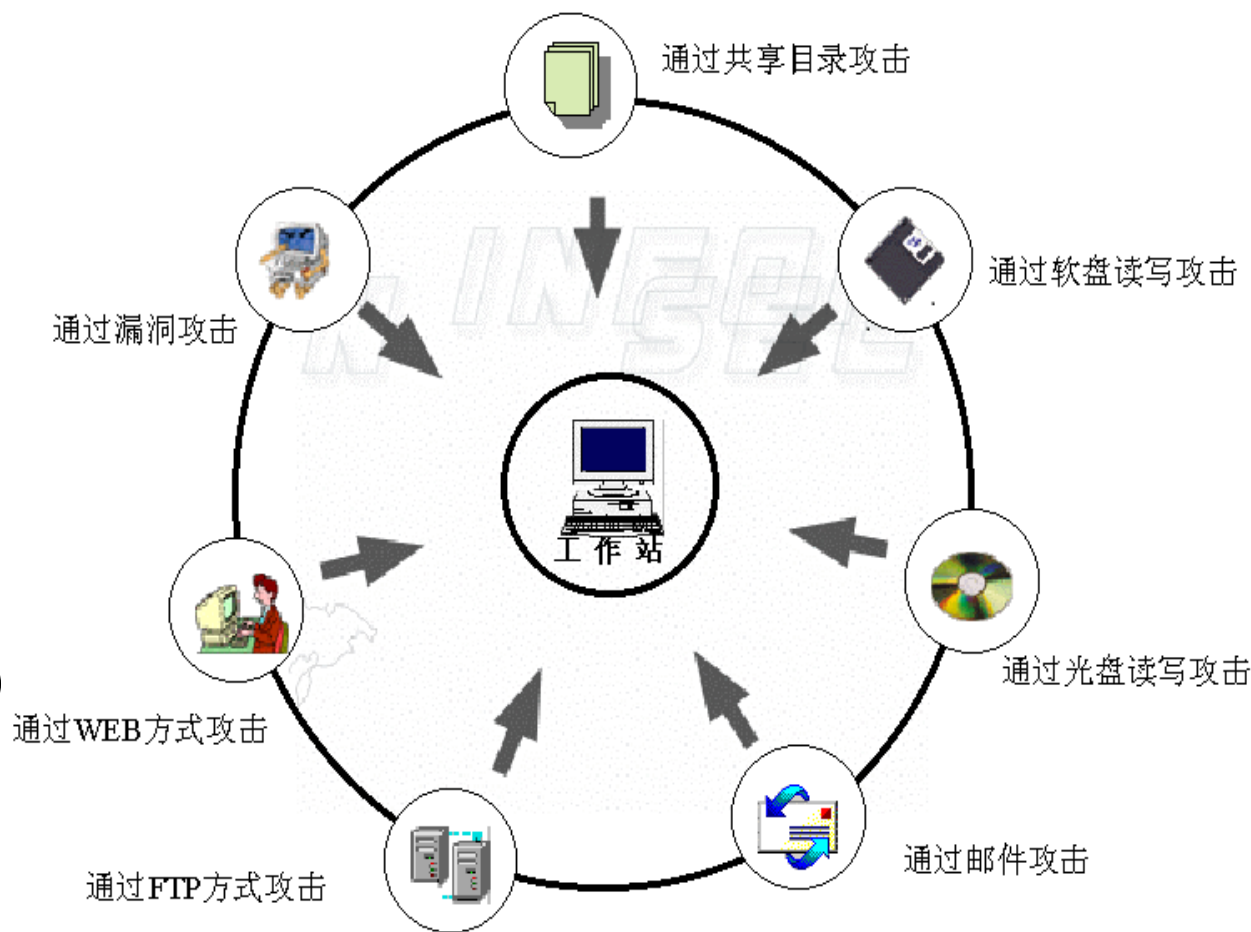
开启后门，作为攻击其他计算机的起点/（肉鸡）

隐藏在你主机上的所有活动

诱骗访问恶意网站

.....

恶意行为



攻击方式

03.软件系统安全：计算机病毒

概念：编制或者在计算机程序中插入的破坏计算机功能或者毁坏数据，影响计算机使用，并能自我复制的一组计算机指令或者程序代码

特征：复制、感染、隐蔽、破坏

危害：病毒运行后能够损坏文件、使系统瘫痪，从而造成各种难以预料的后果。网络环境下，计算机病毒种类越来越多、传染速度也越来越快、危害更是越来越大

防治：以防为主，病原体(病毒库)是病毒防治技术的关键

结构：病毒起作用的关键是被感染的程序调用时先执行病毒代码，之后再执行原本的程序代码，病毒通用结构如右：

```
program V: =  
{  goto main;  
  1234567;  
  subroutine infect-executable := { loop:  
    file := get-random-executable-file;  
    if (first-line-of-file = 1234567) then goto loop else prepend V to file;}  
  subroutine do-damage := {whatever damage is to be done}  
  subroutine trigger-pulled := { return true if some condition holds}  
main: main-program := {  infect-executable;  
                        if trigger-pulled then do-damage;  
                        goto next;}  
  
next:  
}
```


03.软件系统安全：计算机病毒/恶意软件防治

计算机病毒传播方式

- 第一种途径：通过不可移动的**计算机硬件设备**进行传播
- 第二种途径：通过**移动存储设备**来传播这些设备包括软盘、磁带等
- 第三种途径：通过**计算机网络**(邮件、网页、局域网、远程攻击、网络下载)进行传播。计算机病毒可以附着在正常文件中通过网络进入一个又一个系统
- 第四种途径：通过点对点通信系统和**无线通道**传播

防治技术概括为6个层次：

- 检测
- 清除
- 预防（被动防治）
- 免疫（主动防治）
- 防范策略
- 数据备份及恢复

三分技术、七分管理、十二分数据

03.软件系统安全：黑客（Hacker）与骇客（Cracker）



假冒用户
违法用户
隐秘用户

入侵(Intrusion): 指任何企图危及资源的完整性、机密性和可用性的活动。不仅包括发起攻击的人(如恶意的黑客)取得超出合法范围的系统控制权, 也包括收集漏洞信息, 造成拒绝服务等对计算机系统产生危害的行为。

真正黑客具备四种基本素质: “Free” 精神、探索与创新精神、反传统精神和合作精神。

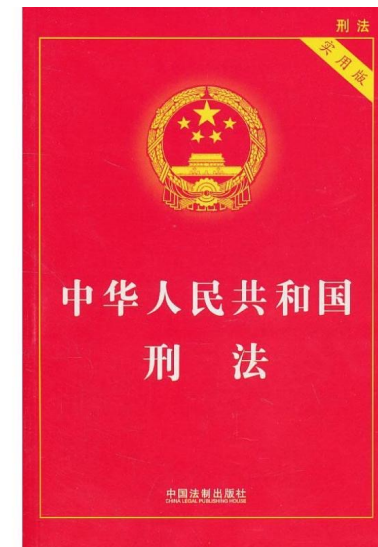
03.软件系统安全：相关法律法规

《刑法》第二百八十五条【非法侵入计算机信息系统罪】

- 违反国家规定，侵入国家事务、国防建设、尖端科学技术领域的计算机信息系统的，处三年以下有期徒刑或者拘役。

《刑法》第二百八十六条【破坏计算机信息系统罪】

- 违反国家规定，对计算机信息系统功能进行删除、修改、增加、干扰，造成计算机信息系统不能正常运行，后果严重的，处五年以下有期徒刑或者拘役；
- 后果特别严重的，处五年以上有期徒刑。





目 录

01

基础知识概述

02

密码学

03

软件系统与安全

04

网络信息安全

04.网络信息安全：网络空间内涵与外延

网络空间已经成为继陆、海、空、天之外的第五维国家安全领域

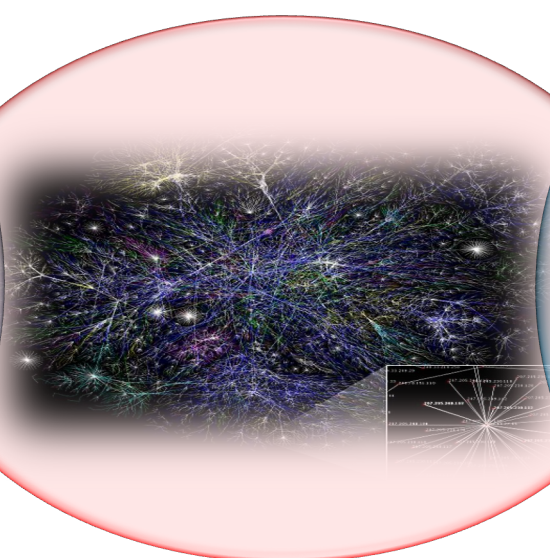
国家与社会安全

信息安全

基础设施安全



人类社会(人)



信息世界(机)



物理世界(物)

网络空间与现实世界相互渗透，推进人机物三元融合

网络安全和信息化是一体之两翼、驱动之双轮，必须统一谋划、统一部署、统一推进、统一实施。

——《努力把我国建设成为网络强国》
(2014年2月27日)

人民网 时习之
cpc.people.cn

04.网络信息安全：国家高度重视网络空间安全

网络安全成为国家战略

2013年11月12日，中央国家安全委员会正式成立

2014年02月27日，中央网络安全和信息化领导小组成立

2017年6月，我国网络安全领域的基本法《中华人民共和国网络安全法》正式实施

提升到国家战略

高度重视网络空间安全保障工作

- 加快构建关键信息基础设施安全保障体系
- 全天候全方位感知网络安全态势
- 增强网络安全防御能力和威慑能力
- 要有高素质的网络安全和信息化人才队伍



没有信息化就没有现代化

——2018年2月27日，习近平在中央网络安全和信息化领导小组第一次会议上的讲话

没有网络安全就没有国家安全

——2018年4月21日，习近平在全国网络安全和信息化工作会议上的讲话

04.网络信息安全：网络空间安全威胁演化

1960-1990

1990-2000

2000-2010

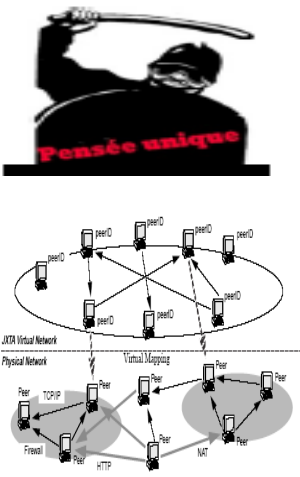
2010-2020



精确打击
物理压制



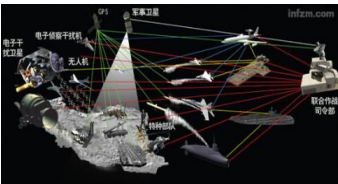
链路对抗



重要节点威胁



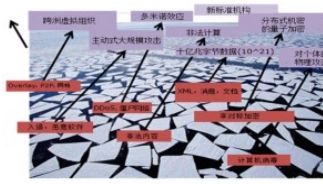
泛在威胁



• 电子对抗



• 网络对抗



• 算法对抗



• 社工对抗

04.网络信息安全：什么是社会工程学

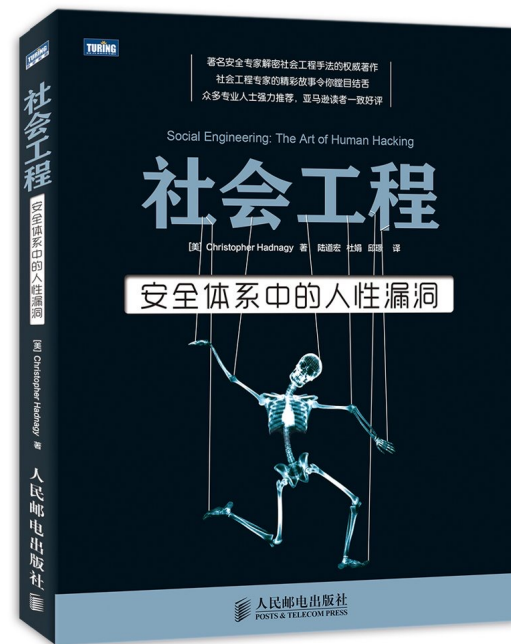
在安全爱好者的眼里各有各的理
解

社会工程是欺骗别人以获取信息

社工工程就是做一个好演员

社会工程是知道怎样免费获得东

西学会识别社会工程攻击，提高信息安全意识！



平安交大 >



01 总体情况

根据公安机关立案数据显示：2021年7月，我校共发生各类案件8起，其中刑事案件5起、治安案件3起，主要为网络诈骗、肢体冲突类案件。**网络诈骗**类案件占比**62.5%**，其中网络资源购买类1起、冒充客服类2起、网络购物类1起、裸聊诈骗类1起。

04.网络信息安全：常见黑客社会工程学手段

恐吓：社会工程学师常常利用人们对安全，漏洞，病毒，木马的敏感性，以权威机构的身份出现，使用危言耸听的伎俩恐吓欺骗计算机用户，以使用户言听计从。

例：欺诈短信 “你在担任教育局领导期间曾经贪污，收受他人红包、购物卡、礼品等。现中纪委检查组已进驻杭州，如果不想下半辈子在监狱度过，你得在明天中午12时前汇5万元到指定银行卡内。”

伪装：用来网络钓鱼的银行页面，例如URL里把真实网址的o换成0，让人真假难辨。

2025/11/12

上海交通大学--计算机科学导论--信息安全

误上钓鱼网站70万瞬间没了
原来是用户登录了假中国银行网站，中行昨晚已发出安全提示



假中国银行网站比真的中行网址多了‘cr’两个字母。截屏图

04.网络信息安全：常见黑客社会工程学手段

恭维：高明的黑客精通心理学，人际关系学等社会工程学方面的知识 & 技能善于利用人类的本能反应，好奇心、盲目信任等人性弱点，掌握说话的艺术迎合目标对象，投其所好，往往目标人物会友善的对待。

精准的马屁会让人不自觉的泄露更多信息
俗话说 酒后吐真言，喝酒后泄露信息是喝酒前的10倍概率。

说服：以利益引诱，说服内部员工配合攻击者收集信息，如果内部员工本来就心存不满甚至有了报复的念头，攻击就更容易达成，千防万防，家贼难防。

支付宝被曝“内鬼”贩卖用户资料 辩称不含核心信息

2014年01月06日 09:45:20 来源：深圳商报 分享到：



日前，一则“[支付宝](#)闹内鬼20G用户信息被盗卖”的消息在网上不胫而走，引起了人们的广泛关注。对此，支付宝回应称，对于由此给用户带来的不安深表歉意，对此类事件将一查到底。

据上述消息透露，2013年11月27日，从事电商工作的张某因“涉嫌非法获取公民个人信息罪”，而被杭州市公安局西湖分局刑事拘留。而张某案后牵出一个叫[李某](#)的人，他是阿里巴巴旗下支付宝的前技术员工，利用工作之便，在2010年分多次在公司后台下载了支付宝用户的资料，资料内容超20G。李某与两名同伙，将用户信息多次出售给电商公司、数据公司。

杭州警方以该市翠苑派出所为主体，将上述四人予以控制。犯罪嫌疑人张建系李明团伙的第一个“客户”，其以500元的代价，从李某处购得3万条支付宝[用户信息](#)。

据称，这些用户资料中，包括公民个人的实名、手机、电子邮箱、家庭住址、消费记录等。这些信息对普通人可能没用，但对于一些电商来说，从这些定位精准的用户信息中，可以掌握目标消费群体的具体信息。

04.网络信息安全：社会工程学防范

1. 及时更新操作系统和应用程序软件

任何软件都会不停的被发现漏洞，及时的更新软件能让很多攻击失效。

2. 定期更新系统密码

在各个网站上使用不同的密码，定一个自己的密码规则。

3. 学习社工工程案例

看一些别人被怎么欺骗的。关注各类新闻信息免受骗。

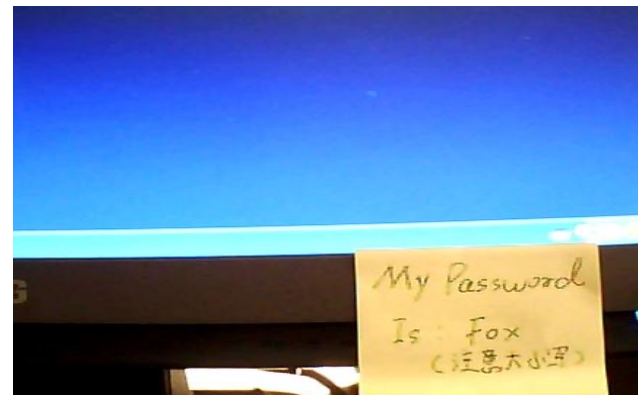
例如各类电话诈骗。

4. 检测发现社交网站的泄露信息

自行或交互社工搜索演练



windows系统漏洞



错误的密码使用习惯

进一步的思考：归零者文明——可信计算

网络信息系统初始设计中不考虑安全，使现在的系统有修不完的墙，堵不尽的洞，杀不完敌人。

边界安全是否已经走到尽头？

网络信息系统是否可以实现安全？

网络信息安全的根本措施是什么？

可信计算可信吗？

基本知识概述

- 信息安全分层结构、信息安全三角结构、常见攻击形式、信息安全体系结构、信息安全保障、TCSEC

密码学

- 密码学发展史、古典密码（密码棒、凯撒密码、维吉尼亚密码、恩格玛机）、现代密码（RSA算法）

软件系统安全

- 恶意软件、计算机病毒、黑客与骇客、相关法律法规

网络信息安全

- 网络空间的内涵、社会工程学的常见手段、社会工程学的防范手段、归零者文明—可信计算

谢谢!



privacy